

CEN/CLC/JTC 13/WG 9 "Horizontal cybersecurity for products with digital elements"

Convenor: Kokx Ben Mr



WI JT013090 draft for final EC review

Document type	Related content	Document date	Expected action
Project / Draft	Project: JT013090 - prEN 40000-1-3	2026-08-03	

1
2
3
4
5

CEN/CLC/JTC 13

Date: 2026-08-03

prEN 40000-1-3

Secretariat: DIN

WI Number: JT013090

6 **Cybersecurity requirements for products with digital elements -**
7 **Part 1-3: Vulnerability handling**

8

ICS: 35.030

9

CCMC will prepare and attach the official title page.

10	Contents.....	Page
11	European foreword.....	3
12	Introduction	4
13	1 Scope	6
14	2 Normative references	6
15	3 Terms and definitions	6
16	4 Structure of this document	6
17	5 Vulnerability handling	7
18	5.1 General	7
19	5.2 [PRE] Preparation	7
20	5.3 [RCP] Receipt	27
21	5.4 [VRF] Verification	35
22	5.5 [RMD] Remediation	41
23	5.6 [RLS] Release	47
24	5.7 [PRA] Post-release activities	53
25	Annex A (informative) Mapping of vulnerability handling activities to identified	
26	risks.....	55
27	Annex B (informative) Relationships of this document with other international	
28	standards.....	58
29	Annex C (informative) Additional guidance on vulnerability handling	60
30	Annex ZA (informative) Relationship between this European Standard and the	
31	essential cybersecurity requirements of Regulation (EU) 2024/2847 of the	
32	European Parliament and of the Council of 23 October 2024 on horizontal	
33	cybersecurity requirements for products with digital elements and amending	
34	Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU)	
35	2020/1828 (Cyber Resilience Act) aimed to be covered	68
36	Bibliography	70
37		

38 **European foreword**

39 This document (prEN 40000-1-3:2026) has been prepared by Technical Committee CEN/CLC JTC
40 13 “Cybersecurity and Data Protection”, the secretariat of which is held by DIN.

41 This document is currently submitted to the CEN Enquiry.

42 This document has been prepared under a standardization request addressed to CEN-CENELEC
43 by the European Commission. The Standing Committee of the EFTA States subsequently approves
44 these requests for its Member States.

45 For the relationship with EU Legislation, see informative Annex ZA, which is an integral part of
46 this document.

47 Introduction

48 Vulnerabilities can emerge throughout the life cycle of a product with digital elements
 49 (hereinafter referred to as "product"). It triggers the need to establish and maintain an effective
 50 vulnerability handling process to identify, assess, remediate, disclose and monitor vulnerabilities
 51 in a timely and systematic manner. The generic risks related to the failure to implement specific
 52 vulnerability handling activities are highlighted in the informative Annex A.

53 Regulation (EU) 2024/2847 (CRA) ^[1] establishes essential cybersecurity requirements relating
 54 to vulnerability handling. This document supports the implementation of these requirements by
 55 specifying process requirements for coordinated vulnerability disclosure (CVD) and vulnerability
 56 handling. It leverages internationally recognised practices as highlighted in Annex B, while
 57 incorporating additional requirements supporting Regulation (EU) 2024/2847 (CRA) ^[1].
 58 Additionally it addresses supporting activities such as vulnerability monitoring, security testing,
 59 software and hardware component management and security update management and current
 60 good practices for multi-party coordination during vulnerability handling and coordinated
 61 vulnerability disclosure (CVD).

62 The activities specified in this document are intended to be implemented using a risk-based
 63 approach. The implementation of the vulnerability handling process is to be proportionate to the
 64 product's cybersecurity risks assessment.

65 The vulnerability handling activities defined in this document are organised into the following
 66 phases:

- 67 — **Preparation:** establishing the capabilities and activities supporting vulnerability handling.
- 68 — **Receipt:** identifying and monitoring potential vulnerabilities from either internal and
 69 external sources.
- 70 — **Verification:** validating vulnerabilities and assessing their applicability and risk.
- 71 — **Remediation:** planning, developing and verifying corrective actions or mitigations.
- 72 — **Release:** making remediation measures and advisory available to relevant stakeholders.
- 73 — **Post-release:** monitoring the effectiveness of remediation activities and improving the
 74 vulnerability handling process.

75 The structured application of these activities supports consistent vulnerability handling
 76 throughout the support period of the product and facilitates communication and coordination
 77 between relevant stakeholders.

78 EN 40000-1-3 is part of a set of standards requested by standardization request M/606 ^[2] to
 79 support the Cyber Resilience Act (CRA) ^[1] compliance that have the following structure:

- 80 — Horizontal standards for cybersecurity requirements relating to the properties of products
 81 with digital elements, including:
 - 82 — EN 40000-1-1, Cybersecurity requirements for products with digital elements - Part 1-1:
 83 Vocabulary;
 - 84 — EN 40000-1-2, Cybersecurity requirements for products with digital elements - Part 1-2:
 85 Principles, product risk management, and life cycle activities;

- 86 — EN 40000-1-3, Cybersecurity requirements for products with digital elements - Part 1-3:
87 Vulnerability Handling (this document);
- 88 — EN 40000-1-4, Cybersecurity requirements for products with digital elements - Generic
89 Security Requirements.
- 90 — Vertical standards for cybersecurity requirements relating to the properties of products with
91 digital elements covering product category specific requirements.

1 Scope

This document specifies requirements for vulnerability handling applicable to products with digital elements (hereinafter referred to as "product"). Implementing these requirements enables a manufacturer to ensure cybersecurity is maintained throughout the product support period.

This document is intended to support the compliance with the essential cybersecurity requirements relating to vulnerability handling set out in Annex I, Part II of Regulation (EU) 2024/2847 (CRA) ^[1].

2 Normative references

The following documents are referred to in the text in such a way that some or all of their content constitutes requirements of this document. For dated references, only the edition cited applies. For undated references, the latest edition of the referenced document (including any amendments) applies.

prEN 40000-1-1, *Cybersecurity requirements for products with digital elements - Vocabulary*

3 Terms and definitions

For the purposes of this document, the terms and definitions given in Regulation (EU) 2024/2847 (CRA) ^[1], prEN 40000-1-1 and the following apply.

ISO and IEC maintain terminology databases for use in standardization at the following addresses:

- ISO Online browsing platform: available at <http://www.iso.org/obp>
- IEC Electropedia: available at <http://www.electropedia.org/>

4 Structure of this document

This document is organized into activities representing the main phases of the vulnerability handling process.

The activities and corresponding abbreviations are:

- **PRE:** Preparation
- **RCP:** Receipt
- **VRF:** Verification
- **RMD:** Remediation
- **RLS:** Release
- **PRA:** Post-release activities

Each activity contains one or more sub-activities. Sub-activities are identified by the activity abbreviation followed by a sequential number, for example PRE-1 or RLS-2.

124 Each sub-activity contains one or more requirements and can also include recommendations or
125 permissions. These provisions are uniquely identified using the sub-activities identifier followed
126 by:

127 — **RQ** for a requirement

128 — **RC** for a recommendation

129 Each provision is assigned a sequential two-digit number within its sub-activity.

130 EXAMPLE

131 — PRE-1-RQ-01

132 — PRE-2-RQ-02

133 — PRE-1-RC-01

134 **5 Vulnerability handling**

135 **5.1 General**

136 This document specifies the activities and associated requirements for vulnerability handling to
137 maintain and improve the cybersecurity of products. These activities support the timely and
138 effective handling of vulnerabilities, contributing to the reduction of cybersecurity risks
139 throughout the product life cycle.

140 Where documented evidence of inputs or outputs is unavailable for example because an incident
141 or CVD report has not yet occurred, the assessment can be performed using simulated process
142 activities, or where applicable, using the evidence of plans, procedures and assignment of
143 responsibilities.

144 For additional guidance on implementing the vulnerability handling process, refer to Annex C.

145 **5.2 [PRE] Preparation**

146 **5.2.1 General**

147 The preparation phase establishes the policies, processes, and capabilities needed to effectively
148 manage vulnerabilities throughout the product life cycle. It ensures that the manufacturer has the
149 necessary policies, processes, and capabilities in place before vulnerabilities are identified and
150 managed.

151 This activity provides a framework to support:

152 — identification and management of vulnerabilities;

153 — consistent and repeatable handling of vulnerability related activities;

154 — coordinated communication with internal and external stakeholders.

155 The preparation activity also ensures the maintenance of sufficient visibility of the product
156 composition, including software and hardware components, which is essential for determining
157 vulnerability impact and preparation for secure distribution of updates and related information.

158 It is important to note that in the scope of the product composition, build tools and libraries can
 159 have an impact on the outcomes and therefore can be considered as inputs.

160 **5.2.2 [PRE-1] Vulnerability handling policy**

161 **5.2.2.1 General**

162 A vulnerability handling policy provides a governance framework and structured approach to
 163 managing product vulnerabilities throughout the product life cycle. It defines how vulnerability
 164 related activities such as monitoring, investigation, remediation, and communication are
 165 conducted. The policy clarifies responsibilities, decision making criteria, and confidentiality
 166 requirements to ensure consistent application. By establishing a unified internal framework, the
 167 policy enables:

- 168 — consistent and repeatable handling of vulnerabilities;
- 169 — alignment between the different stakeholders involved in vulnerability management;
- 170 — efficient coordination of activities defined in the vulnerability handling life cycle.

171 No specific order of creation is implied between the vulnerability handling policy and the CVD
 172 policy; only their consistency matters.

173 **5.2.2.2 Input**

174 The following inputs shall be considered:

- 175 a) CVD policy (see 5.2.3).

176 The following inputs should be considered:

- 177 b) Any documents relevant for vulnerability handling.

178 **EXAMPLE** Example of possible documents relevant for vulnerability handling can be: procedures,
 179 templates, work instructions, company policies, risk-assessment procedures, secure development
 180 practices, or other policies describing cybersecurity responsibilities within the manufacturer's
 181 organization

182 **5.2.2.3 Requirements**

183 **5.2.2.3.1 [PRE-1-RQ-01]**

184 A vulnerability handling policy shall be established, documented, implemented and maintained
 185 (see 5.2.2.3.3).

186 **5.2.2.3.2 [PRE-1-RQ-02]**

187 A vulnerability handling policy shall include at least:

- 188 a) guidance, principles, and responsibilities, for handling potential vulnerabilities in a product;
- 189 b) processes for receiving, assessing, and remediating vulnerabilities;
- 190 c) measures to prevent premature disclosure of information about potential vulnerabilities
- 191 before they are remediated (see 5.2.4);

- 192 d) a target schedule for remediation development;
- 193 e) conditions for expedited handling, including criteria for triggering such handling and
194 applicable timelines or response expectations;
- 195 f) An element of strategy to establish, document, and maintain relationships with downstream
196 stakeholders, where known and appropriate.

197 NOTE Appropriateness depends on privacy and confidentiality agreements with downstream
198 stakeholders.

199 **5.2.2.3.3 [PRE-1-RQ-03]**

200 The vulnerability handling policy and processes shall be periodically reviewed and updated as
201 necessary to ensure their continued suitability and effectiveness.

202 **5.2.2.3.4 [PRE-1-RQ-04]**

203 A strategy to establish, document and maintain relationships with upstream stakeholders,
204 including open-source dependencies, shall be required to support vulnerability handling policy
205 in the coordination and notification activities when a vulnerability is discovered.

206 NOTE The components identification required by 5.2.6 and 5.2.7 is supporting the identification of the
207 relevant upstream stakeholder.

208 **5.2.2.4 Recommendations**

209 **5.2.2.4.1 [PRE-1-RC-01]**

210 An information sharing strategy and a disclosure strategy should be established and documented
211 to prevent premature public disclosure of vulnerability information before appropriate
212 remediation actions have been completed and a coordinated disclosure approach has been
213 agreed. The strategy should include at least:

- 214 a) A description of the specific information which is to be shared with the parties involved,
215 before public disclosure;
- 216 b) defined conditions under which vulnerability information can be shared with stakeholders;
- 217 c) defined responsibilities for disclosure decision-making;
- 218 d) procedures for coordinating disclosure with affected stakeholders;
- 219 e) criteria for determining and applying embargo period;
- 220 f) criteria for determining public disclosure timing.

221 NOTE 1 Embargo periods can be defined on a per vulnerability basis and can be negotiated and adjusted
222 by mutual agreement between manufacturers, reporters, and coordinators, where applicable.

223 NOTE 2 A vulnerability disclosure strategy includes the flexibility to address different types of
224 vulnerabilities; reports, timelines, and responses can be tailored to each case and agreed upon by the
225 stakeholders involved.

5.2.2.5 Output

Outputs shall include:

- a) Vulnerability handling policy.

5.2.2.6 Assessment criteria

To demonstrate conformity to this clause the following criteria shall be met:

[PRE-1-RQ-01] (see 5.2.2.3.1)

- a) A documented vulnerability handling policy exists;
- b) Evidence that the policy is implemented and maintained.

[PRE-1-RQ-02] (see 5.2.2.3.2)

- c) The vulnerability handling policy defines all the elements required.

[PRE-1-RQ-03] (see 5.2.2.3.3)

- d) Evidence that the vulnerability handling policy is reviewed according to the defined review process.

[PRE-1-RQ-04] (see 5.2.2.3.4) and **[PRE-1-RQ-02]** (see 5.2.2.3.2)

- e) Evidence that the vulnerability handling policy includes or references a strategy to establish, document and maintain relationships with upstream and downstream stakeholders, including open-source dependencies, to support the coordination and notification activities when a vulnerability is discovered.

The verdict PASS is assigned if all the assessment criteria have been fulfilled.

5.2.3 **[PRE-2] Coordinated vulnerability disclosure policy**

5.2.3.1 General

A CVD policy defines the principles, expectations, and processes for vulnerability disclosure in a controlled and responsible way. Effective coordination is needed because disclosure often involves multiple parties, including reporters, manufacturers and other upstream stakeholders, and users. Without clear guidance, disclosure could potentially happen prematurely or inconsistently, increasing the risk of exploitation or misalignment between stakeholders.

This policy ensures that:

- vulnerabilities are disclosed in a timely, coordinated, and controlled manner;
- communication between stakeholders is structured and transparent;
- remediation activities are completed or sufficiently advanced before public disclosure;
- sensitive vulnerability information is protected during handling.

257 The CVD policy is aligned with the vulnerability handling policy, ensuring consistency between
258 internal processes and external communication. The intended audience of the CVD policy
259 includes both internal and external stakeholders.

260 **5.2.3.2 Input**

261 The following inputs shall be considered:

262 a) Vulnerability handling policy (see 5.2.2).

263 **5.2.3.3 Requirements**

264 **5.2.3.3.1 [PRE-2-RQ-01]**

265 A CVD policy shall be established, documented, implemented, maintained, and published in an
266 accessible format.

267 NOTE For additional guidance on accessibility requirements, refer to [EN 301 549 v3.2.1](#).

268 **5.2.3.3.2 [PRE-2-RQ-02]**

269 A CVD policy shall be consistent with, and support, the vulnerability handling policy as described
270 in 5.2.2.

271 **5.2.3.3.3 [PRE-2-RQ-03]**

272 A CVD policy shall define one or more publicly available contact mechanisms to receive
273 vulnerability information or reports.

274 NOTE Contact information is available for both reporting vulnerabilities and requesting additional
275 information about the coordinated vulnerability program.

276 A list of possible contact mechanisms includes but is not limited to:

- 277 — e-mail address, preferably aliases, mailing lists, or role-based accounts that are not tied to a specific
278 individual;
- 279 — web-based submission forms;
- 280 — bug or issue tracking systems;
- 281 — phone number or similar;
- 282 — contact information for customer service;
- 283 — dedicated vulnerability reporting services.

284 **5.2.3.3.4 [PRE-2-RQ-04]**

285 A CVD policy shall explicitly define expectations for on-going communication (see 5.2.5) between
286 involved parties (e.g. reporters, manufacturers, coordinators) including at least:

- 287 a) communication channels to be used;
- 288 b) expected acknowledgement, response, and update time-frames;
- 289 c) conditions for sharing information with third parties;

290 d) coordination of public disclosure, including the use of embargo periods.

291 NOTE 1 Communication expectations are to be treated as adaptable and subject to revision throughout
292 the life cycle of the vulnerability handling process to reflect evolving technical or supply chain constraints.

293 NOTE 2 Confidentiality requirements related to vulnerability information are addressed in 5.2.4.

294 **5.2.3.3.5 [PRE-2-RQ-05]**

295 A CVD policy shall include the following elements:

296 a) vulnerability report content expectations;

297 b) scope of the policy;

298 c) publication practices describing how advisories and remediation are distributed (see 5.2.9);

299 d) recognition of reporters.

300 **5.2.3.4 Recommendations**

301 **5.2.3.4.1 [PRE-2-RC-01]**

302 A CVD policy should include provisions supporting good faith vulnerability reporting, including
303 explicit authorization for non malicious security testing.

304 **5.2.3.4.2 [PRE-2-RC-02]**

305 The contact mechanisms should provide accessibility via more than one sensory channel.

306 EXAMPLE The purpose of providing more than one sensory channel is to address situations in which
307 a potential user with a writing impediment can still, for example, call a phone number to ask for and provide
308 information.

309 **5.2.3.5 Output**

310 Outputs shall include:

311 a) CVD policy.

312 **5.2.3.6 Assessment criteria**

313 To demonstrate conformity to this clause the following criteria shall be met:

314 **[PRE-2-RQ-01]** (see 5.2.3.3.1)

315 a) A documented CVD policy exists and is published in an accessible format;

316 b) Evidence that the policy is implemented and maintained.

317 **[PRE-2-RQ-02]** (see 5.2.3.3.2)

318 c) The CVD policy is consistent with, and supports, the activities defined in the vulnerability
319 handling policy (see 5.2.2).

320 **[PRE-2-RQ-03]** (see 5.2.3.3.3)

321 d) Contact mechanisms are publicly available.

322 **[PRE-2-RQ-04]** (see 5.2.3.3.4)

323 e) The CVD policy explicitly defines expectations for communication between involved parties.

324 **[PRE-2-RQ-05]** (see 5.2.3.3.5)

325 f) The CVD policy contains at least the required elements.

326 The verdict PASS is assigned if all the assessment criteria have been fulfilled.

327 **5.2.4 [PRE-3] Confidentiality of vulnerability information**

328 **5.2.4.1 General**

329 Information about vulnerabilities can be sensitive and increase cybersecurity risks if disclosed to
330 unauthorized parties before appropriate remediation measures are available. Confidential
331 handling of vulnerability information is therefore necessary to support the effective coordination,
332 assessment, remediation, and disclosure of vulnerabilities.

333 Confidentiality of vulnerability information implies both operational protection measures and
334 secure communication mechanisms. Operational protection measures ensure that vulnerability
335 information is appropriately handled, stored, accessed, and disclosed throughout the
336 vulnerability handling life cycle. Secure communication mechanisms support the protected
337 exchange of vulnerability information between authorized parties and help preserve its
338 confidentiality, integrity, and authenticity during transmission.

339 Maintaining confidentiality helps reduce the likelihood that vulnerability information is misused
340 before affected stakeholders have an opportunity to develop, test, release, and apply appropriate
341 remediation measures. This is particularly important where vulnerabilities affect products that
342 are widely deployed, critical components, shared dependencies, or multiple stakeholders.

343 This phase ensures that:

344 — vulnerability information is protected from unauthorized access, use, modification, or
345 disclosure;

346 — vulnerability handling activities can be performed without increasing the risk of exploitation;

347 — CVD activities are supported in accordance with the disclosure policy;

348 — affected stakeholders have sufficient opportunity to develop, validate, release, and deploy
349 remediation measures before public disclosure, where appropriate;

350 — confidentiality obligations and agreed disclosure restrictions, including embargo periods, are
351 respected;

352 — vulnerability information exchanged between internal and external stakeholders is
353 appropriately protected throughout its life cycle and during transmission.

354 Confidentiality requirements apply to vulnerability reports, technical details, proof-of-concept
355 information, root-cause analysis results, remediation information, and communications
356 exchanged between internal and external stakeholders during vulnerability handling activities.

5.2.4.2 Input

The following inputs shall be considered:

- a) Vulnerability handling policy (see 5.2.2);
- b) CVD policy (see 5.2.3).

5.2.4.3 Requirements

5.2.4.3.1 [PRE-3-RQ-01]

Operational security shall be considered throughout the activities of receiving (see 5.3.2) and communicating about (see 5.2.5) vulnerability information or reports.

5.2.4.3.2 [PRE-3-RQ-02]

Access to non-public vulnerability information shall be restricted to a "need-to-know" basis to protect sensitive vulnerability reports.

5.2.4.3.3 [PRE-3-RQ-03]

Where secure communication mechanism(s) are implemented (see 5.2.4.4 [PRE-3-RC-01]), the information about secure communication mechanism(s) shall be made publicly available and clearly communicated to stakeholders.

5.2.4.3.4 [PRE-3-RQ-04]

Where secure communication mechanism(s) are implemented (see 5.2.4.4 [PRE-3-RC-01]), secure communication mechanism(s) shall be designed to preserve the accessibility of reporting and communication channels.

5.2.4.3.5 [PRE-3-RQ-05]

Received vulnerability reports shall not be rejected on the basis of the communication channel used by a reporter or relevant stakeholder.

5.2.4.4 Recommendations

5.2.4.4.1 [PRE-3-RC-01]

Secure communication mechanisms should be provided and implemented to support the receipt and exchange of vulnerability information, aligned with the reporting and contact mechanisms (see 5.2.3).

NOTE 1 Because the initial contact by the reporter can occur via any communication channel, the manufacturer can accept and register such reports and, where sensitive information is involved, offer continuation via secure communication mechanisms.

NOTE 2 While secure communication mechanisms are encouraged, their use is not mandatory as reporters can choose other mechanisms as listed in the CVD policy (see 5.2.3 [PRE-2-RQ-03]).

EXAMPLE Example of secure communications can be:

- web-based forms or applications using TLS (HTTPS);
- e-mail encryption and signing using S/MIME or OpenPGP.

392 5.2.4.5 Output

393 Outputs shall include:

- 394 a) Documented operational security measures applied during vulnerability handling, including
395 how to determine the level of confidentiality and related restrictions for vulnerability
396 reports.

397 Where secure communication mechanisms are implemented, the following outputs shall be
398 available:

- 399 b) Documentation describing the secure communication mechanisms in use;
400 c) Public documentation describing available secure communication mechanisms;

401 5.2.4.6 Assessment Criteria

402 To demonstrate conformity to this clause the following criteria shall be met:

403 [PRE-3-RQ-01] (see 5.2.4.3.1)

- 404 a) Evidence demonstrating the implementation of mechanisms to securely receive vulnerability
405 reports, where applicable;
406 b) Evidence demonstrating the implementation of mechanisms to securely share vulnerability
407 reports or vulnerability information, where applicable.

408 [PRE-3-RQ-02] (see 5.2.4.3.2)

- 409 c) Evidence demonstrating that security control mechanisms (operational or technical) enforce
410 need-to-know restrictions.

411 [PRE-3-RQ-03] (see 5.2.4.3.3)

- 412 d) Evidence on how information about secure communication mechanism(s) have been made
413 publicly available and communicated to the stakeholders, where applicable.

414 [PRE-3-RQ-04] (see 5.2.4.3.4)

- 415 e) Evidence that secure communication mechanism(s) do not hinder accessibility (e.g.
416 availability of alternative channels or usability validation), where applicable

417 [PRE-3-RQ-05] (see 5.2.4.3.5)

- 418 f) Evidence that the vulnerability report received is not rejected only because of the
419 communication channel used.

420 The verdict PASS is assigned if all the assessment criteria have been fulfilled.

421 5.2.5 [PRE-4] On-going communication

422 5.2.5.1 General

423 Effective vulnerability handling requires continuous, coordinated communication among all
424 relevant stakeholders throughout the product life cycle. Vulnerability activities involve multiple
425 parties, including internal teams and external stakeholders such as reporters, users, upstream

426 stakeholders, maintainers, and coordinators. Communication is not a discrete step but a cross-
 427 cutting activity supporting all phases of vulnerability handling, including receipt, verification,
 428 remediation, and disclosure.

429 Maintaining ongoing communication ensures that:

- 430 — stakeholders are informed of relevant developments;
- 431 — coordination activities are performed effectively;
- 432 — expectations are aligned regarding timelines, responsibilities, and outcomes;
- 433 — misunderstandings, delays, and inconsistencies are minimized.

434 Effective communication also supports transparency and trust, especially when vulnerabilities
 435 involve multiple parties or shared responsibilities such as open-source ecosystems or supply
 436 chains.

437 **5.2.5.2 Input**

438 The following inputs shall be considered:

- 439 a) CVD policy (see 5.2.3).

440 The following inputs should be considered, where applicable:

- 441 b) Vulnerability report from internal or external source (see 5.3.3);
- 442 c) Verified vulnerability report including an initial assessment of the vulnerability and its
 443 reported severity (see 5.4.2);
- 444 d) Results of the Vulnerability risk assessment (see 5.4.3);
- 445 e) Remediation plan (see 5.5.2);
- 446 f) Produced remediation and related documentation (see 5.5.3);
- 447 g) Target schedule for remediation (see 5.2.2).

448 **5.2.5.3 Requirements**

449 **5.2.5.3.1 [PRE-4-RQ-01]**

450 Communication with reporters and other stakeholders shall be established and maintained to
 451 ensure timely, consistent, and appropriate information exchange throughout the vulnerability
 452 handling and disclosure life cycle. The communication shall:

- 453 a) Be aligned with the relevant phase of vulnerability handling and vulnerability disclosure;
- 454 b) Reflect available inputs (e.g. severity, risk, remediation status, timelines), where applicable;
- 455 c) Be performed through defined communication channels;
- 456 d) Be aligned to the role of the stakeholder.

457 **5.2.5.3.2 [PRE-4-RQ-02]**

458 Communication with reporters and other stakeholders shall be supported using at least one
459 accessible mode.

460 NOTE Accessible communication modes include:

- 461 — clear and understandable language;
- 462 — one or more contact channels (e.g. e-mail, web forms, phone);
- 463 — support for assistive technologies;
- 464 — availability of alternative formats when needed.

465 **5.2.5.4 Output**

466 Outputs shall include:

- 467 a) Establishment of the communication mechanisms;
- 468 b) Documentation of the communication with relevant stakeholders, if available;
- 469 c) Evidence of accessible communication mechanisms.

470 **5.2.5.5 Assessment criteria**

471 To demonstrate conformity to this clause the following criteria shall be met:

472 **[PRE-4-RQ-01]** (see 5.2.5.3.1)

- 473 a) Evidence exists that communication activities have been established across the vulnerability
474 handling phases;
- 475 b) Where vulnerability reports have been submitted, evidence exists that communication(s)
476 with stakeholders has been performed and reflects its role;
- 477 c) Such communication, where applicable, reflects the relevant available inputs required.

478 **[PRE-4-RQ-02]** (see 5.2.5.3.2)

- 479 d) Evidence exists that accessible modes of communication are supported.

480 The verdict PASS is assigned if all the assessment criteria have been fulfilled.

481 **5.2.6 [PRE-5] Identification of software components**

482 **5.2.6.1 General**

483 Identifying software components in the product is fundamental for effective vulnerability
484 handling throughout its life cycle. Products typically include proprietary software, third-party
485 components, and open-source dependencies. Vulnerabilities often relate to specific components
486 and versions. Without accurate identification, determining whether a vulnerability affects the
487 product is not possible.

488 This activity ensures that:

- 489 — software components are known and documented;
 - 490 — components are traceable across product versions and configurations;
 - 491 — vulnerability information can be systematically assessed against the product;
 - 492 — risks can be evaluated and managed consistently.
- 493 Maintaining an accurate and up-to-date view of software components enables effective
494 monitoring, impact analysis, and remediation planning.

495 The intended purpose of the product can include scenarios where users or integrators modify
496 installed software components, for example when third-party applications are installed on a
497 computer. Such components are outside the manufacturer's control and are not covered by this
498 requirement.

499 **5.2.6.2 Input**

500 The following inputs shall be considered:

- 501 a) Binary artefacts;
- 502 b) Configuration files;
- 503 c) Source code;
- 504 d) Cybersecurity architecture and design documents;
- 505 e) Product security risk assessment.

506 NOTE 1 For additional guidance on:

- 507 — cybersecurity architecture and design (see [prEN 40000-1-2:2025](#), 7.4);
- 508 — product security risk assessment (see [prEN 40000-1-2:2025](#), 6.4).

509 NOTE 2 For software components integrated as pre-compiled artefacts, the source code is not
510 necessarily required.

511 NOTE 3 The inputs listed are potential sources for identifying software components. The applicable
512 inputs depend on the product characteristics and the manufacturer's role in the supply chain. Not all inputs
513 are required or available for every product.

514 **5.2.6.3 Requirements**

515 **5.2.6.3.1 [PRE-5-RQ-01]**

516 All non third-party components integrated as software components in the product shall be
517 identified and documented.

518 **5.2.6.3.2 [PRE-5-RQ-02]**

519 Third-party components integrated as software components in the product and integrated in the
520 non third-party components as per 5.2.6.3.1 [PRE-5-RQ-01], including at least those that are
521 directly integrated, shall be identified and documented.

522 NOTE It is not always be possible to obtain the necessary information from upstream stakeholders
523 that includes all transitive dependencies of third-party components.

524 **5.2.6.3.3 [PRE-5-RQ-03]**

525 For each component identified in 5.2.6.3.1 [PRE-5-RQ-01] and 5.2.6.3.2 [PRE-5-RQ-02], the
526 following information shall be included:

527 a) Component producer;

528 b) Component name;

529 c) Component version.

530 NOTE 1 In relation to component producer: creates, defines, and identifies components, such as
531 manufacturer or open-source software steward.

532 NOTE 2 In relation to component name: for open-source software, this is the name or reference of the
533 open-source project as stated on the project website or in the repository. For open-source software which
534 is supported by an open-source software steward, it is suggested that the steward is also included.

535 **5.2.6.3.4 [PRE-5-RQ-04]**

536 All the software components identified in 5.2.6.3.1 [PRE-5-RQ-01] and 5.2.6.3.2 [PRE-5-RQ-02]
537 shall be drawn up in the SBOM.

538 **5.2.6.3.5 [PRE-5-RQ-05]**

539 The SBOM shall be assembled in a commonly used and machine-readable format.

540 **5.2.6.3.6 [PRE-5-RQ-06]**

541 If the new build or release version of a software component is released, then a new SBOM shall
542 be created.

543 NOTE This includes software builds to integrate an updated component or dependency.

544 **5.2.6.3.7 [PRE-5-RQ-07]**

545 When new details about the identified components are detected as per 5.2.6.3.3 [PRE-5-RQ-03]
546 or the need to correct an error in an existing SBOM is discovered, a revised SBOM shall be issued.

547 **5.2.6.3.8 [PRE-5-RQ-08]**

548 Metadata for the SBOM shall include:

549 a) SBOM author;

550 b) Version;

551 c) Timestamp.

552 NOTE 1 The SBOM author creates the SBOM data for the product.

553 NOTE 2 Timestamp is used to record the date and time of the SBOM creation and modification by the
554 author.

555 **5.2.6.3.9 [PRE-5-RQ-09]**

556 For each component part of SBOM as 5.2.6.3.4 [PRE-5-RQ-04], the following information shall be
557 included:

- 558 a) Information as required from 5.2.6.3.3 [PRE-5-RQ-03];
- 559 b) Dependency relationship;
- 560 c) Unique component identifier(s), if available.

561 NOTE SBOM information can additionally include licence information of the component.

562 **5.2.6.4 Recommendations**

563 **5.2.6.4.1 [PRE-5-RC-01]**

564 If the component producer provides the component hash value and the corresponding hash
565 algorithm, it should be included in the SBOM.

566 **5.2.6.4.2 [PRE-5-RC-02]**

567 If the SBOM does not include all dependencies, beyond the direct dependencies included in
568 5.2.6.3.2 [PRE-5-RQ-02], the SBOM author should explicitly indicate if dependency relationship
569 of component is incomplete or unknown.

570 **5.2.6.5 Output**

571 Outputs shall include:

- 572 a) List of identified software components;
- 573 b) Software bill of materials (SBOM).

574 **5.2.6.6 Assessment criteria**

575 To demonstrate conformity to this clause the following criteria shall be met:

576 **[PRE-5-RQ-01]** (see 5.2.6.3.1)

- 577 a) A list of all non third-party components integrated in the product exists;
- 578 b) Evidence exists demonstrating the completeness of the identified non third-party software
579 components.

580 **[PRE-5-RQ-02]** (see 5.2.6.3.2)

- 581 c) A list of third-party components integrated in the product exists;
- 582 d) Evidence exists demonstrating the completeness of the identified third-party software
583 components.

584 **[PRE-5-RQ-03]** (see 5.2.6.3.3)

- 585 e) For each software component in the list, the elements as required are documented.

586 **[PRE-5-RQ-04]** (see 5.2.6.3.4)

587 f) An SBOM exists;

588 g) Evidence exists that the SBOM contains all software components.

589 **[PRE-5-RQ-05]** (see 5.2.6.3.5)

590 h) The SBOM is assembled in a commonly used and machine-readable format

591 **[PRE-5-RQ-06]** (see 5.2.6.3.6)

592 i) Evidence of a process or procedure to create a new SBOM exists.

593 **[PRE-5-RQ-07]** (see 5.2.6.3.7)

594 j) Evidence of a process or procedure to create a revised SBOM exists.

595 **[PRE-5-RQ-08]** (see 5.2.6.3.8)

596 k) Metadata of the SBOM contains the elements as required.

597 **[PRE-5-RQ-09]** (see 5.2.6.3.9)

598 l) For each component of the SBOM, information as required.

599 The verdict PASS is assigned if all the assessment criteria have been fulfilled.

600 **5.2.7 [PRE-6] Identification of hardware components**

601 **5.2.7.1 General**

602 Identifying the hardware components in the product is essential to ensure comprehensive
603 vulnerability handling across the entire product architecture. Hardware components including
604 processors, chipsets, embedded devices, and associated firmware can introduce cybersecurity
605 risks from design flaws, configuration weaknesses, or software interface dependencies.
606 Vulnerabilities often affect specific models, revisions, or firmware versions. Without accurate and
607 maintained identification of hardware components, the manufacturer cannot:

608 — determine whether vulnerability information is applicable to the product;

609 — assess risks associated with hardware related vulnerabilities;

610 — plan and implement appropriate mitigation measures.

611 This activity ensures hardware components are known, traceable, and assessable for
612 cybersecurity risks throughout the product life cycle. It enables effective monitoring, impact
613 analysis, and risk management.

614 **5.2.7.2 Input**

615 The following inputs shall be considered:

616 a) Product security risk assessment;

617 b) Cybersecurity architecture and design.

618 NOTE for additional information, for example see [prEN 40000-1-2:2025](#):

619 — 6.4 as related to product security risk assessment;

620 — 7.4 as related to cybersecurity architecture and design.

621 **5.2.7.3 Requirements**

622 **5.2.7.3.1 [PRE-6-RQ-01]**

623 At least hardware components that are directly contained in the product shall be identified and
624 documented.

625 **5.2.7.3.2 [PRE-6-RQ-02]**

626 For each identified hardware component as per 5.2.7.3.1 [PRE-6-RQ-01], the following
627 information, shall be recorded:

628 a) component producer;

629 b) component name;

630 c) component version;

631 d) component identifier;

632 e) if applicable, firmware name, version and related identifiers.

633 Where such information is not available or not sufficient, the manufacturer shall document
634 information that supports vulnerability handling activities.

635 **5.2.7.4 Output**

636 Outputs shall include:

637 a) List of hardware components and related information.

638 **5.2.7.5 Assessment criteria**

639 To demonstrate conformity to this clause the following criteria shall be met:

640 **[PRE-6-RQ-01]** (see 5.2.7.3.1)

641 a) A documented list of hardware components contained in the product exists;

642 b) Evidence exists demonstrating the completeness of the identified list of hardware
643 components, taking into account:

644 1) the product security risk assessment;

645 2) the cybersecurity architecture and design documentation.

646 **[PRE-6-RQ-02]** (see 5.2.7.3.2)

647 c) Evidence demonstrates that the recorded information sufficiently enables the vulnerability
648 handling activities.

649 The verdict PASS is assigned if all the assessment criteria have been fulfilled.

650 **5.2.8 [PRE-7] Planning regular test and reviews**

651 **5.2.8.1 General**

652 Regular testing and reviews are essential to maintain the product's cybersecurity throughout its
653 life cycle, particularly in an evolving threat landscape. While testing and review activities provide
654 operational assurance, their effectiveness depends on structured planning that defines scope,
655 frequency, and methodology. Without this planning, activities might be inconsistent, incomplete,
656 or misaligned with the product's risk profile.

657 This activity ensures that testing and review activities are:

- 658 — proactive rather than reactive;
- 659 — aligned with the product's intended use, operational environment, and exposure;
- 660 — based on risk-based criteria, including the potential impact of vulnerabilities.

661 Formalizing a test and review plan can mitigate the risk of latent vulnerabilities security flaws
662 that emerge after the product is on the market due to new exploitation techniques or changes in
663 the operational environment and risk profile, or remain undetected.

664 **5.2.8.2 Input**

665 The following inputs shall be considered:

- 666 a) Product context;
- 667 b) Cybersecurity architecture and design;
- 668 c) Product cybersecurity risk assessment;
- 669 d) Product cybersecurity verification and validation.

670 NOTE References to the inputs can be found for:

- 671 — Product context in [prEN 40000-1-2:2025](#), 6.2;
- 672 — Cybersecurity architecture and design in [prEN 40000-1-2:2025](#), 7.4;
- 673 — Product cybersecurity risk assessment in [prEN 40000-1-2:2025](#), 6.4;
- 674 — Product cybersecurity verification and validation in [prEN 40000-1-2:2025](#), 7.6.

675 **5.2.8.3 Requirements**

676 **5.2.8.3.1 [PRE-7-RQ-01]**

677 A risk-based plan for security test and review, justifiable for the product context, shall be created
678 and include:

- 679 a) security test cases;
- 680 b) security review activities;

681 c) definition of frequency of specific security test and review activities.

682 NOTE 1 The extent and frequency of the security test and review can be proportionate to the product's
683 type, complexity, scale, and exposure.

684 NOTE 2 A plan can be designed for an individual product, a product class or a product portfolio or
685 product family.

686 NOTE 3 For additional guidance on security test and review activities, refer to [prEN 40000-1-2:2025](#),
687 7.6.

688 EXAMPLE Threat model review, functional security regression testing, fuzz testing, penetration
689 testing, root cause analysis on critical vulnerabilities.

690 **5.2.8.3.2 [PRE-7-RQ-02]**

691 A security test and review plan shall be based on and consider at least:

- 692 a) product context;
- 693 b) cybersecurity architecture and design;
- 694 c) product cybersecurity requirements;
- 695 d) cybersecurity risk assessment;
- 696 e) test cases and test methodologies.

697 NOTE Security testing can incorporate updates in technology, known vulnerabilities, and emerging
698 threats.

699 **5.2.8.3.3 [PRE-7-RQ-03]**

700 As part of the plan security reviews activities shall consider at least the following sources:

- 701 a) the threat landscape applicable to the product;
- 702 b) vulnerabilities found in the product and its components;
- 703 c) vulnerabilities found in similar products of the same manufacturer and their components;
- 704 d) information about the practical conditions of use as obtained by customer feedback, for
705 example, due to support cases;
- 706 e) the assumptions and all inputs of the product cybersecurity risk assessment.

707 **5.2.8.3.4 [PRE-7-RQ-04]**

708 A security test and review plan shall be maintained based on:

- 709 a) results of performed tests and reviews;
- 710 b) identified vulnerabilities or threats;
- 711 c) changes in the product or its operational environment.

712 **5.2.8.4 Recommendations**

713 **5.2.8.4.1 [PRE-7-RC-01]**

714 Security reviews should consider at least the following sources:

- 715 a) relevant standards and publications describing the state-of-the-art in cybersecurity;
- 716 b) vulnerabilities found in similar products and their components.

717 **5.2.8.5 Output**

718 Outputs shall include:

- 719 a) A documented security test and review plan, including any planned updates.

720 **5.2.8.6 Assessment criteria**

721 To demonstrate conformity to this clause the following criteria shall be met:

722 **[PRE-7-RQ-01]** (see 5.2.8.3.1)

- 723 a) Evidence of the existence of the security test and review plan.

724 **[PRE-7-RQ-02]** (see 5.2.8.3.2)

- 725 b) Evidence that the security test plan contains test cases that consider the required elements.

726 **[PRE-7-RQ-03]** (see 5.2.8.3.3)

- 727 c) Evidence that the review plan has been built based on the sources listed.

728 **[PRE-7-RQ-04]** (see 5.2.8.3.4)

- 729 d) Evidence that the security test and review is maintained based on the required elements.

730 The verdict PASS is assigned if all the assessment criteria have been fulfilled.

731 **5.2.9 [PRE-8] Secure distribution mechanism for updates and related information**

732 **5.2.9.1 General**

733 The ability to securely distribute security updates and related vulnerability information is
734 essential to ensure identified vulnerabilities are effectively mitigated once addressed.
735 Vulnerability handling does not end with identification and remediation. It requires that fixes and
736 associated information are reliably communicated to affected stakeholders. Without appropriate
737 distribution mechanisms, remediation actions might not reach users timely, leaving systems
738 exposed to exploitation.

739 This section ensures that the manufacturer establishes the necessary capabilities to:

- 740 — distribute security updates in a timely and controlled manner;
- 741 — communicate vulnerability information to users and other stakeholders;

742 — support both manual and automated update deployment models, depending on the product
743 context.

744 Secure and reliable distribution mechanisms are critical to maintaining the product's security
745 over time, particularly in environments that require rapid response to emerging threats.

746 The preparation of distribution mechanisms could also be relevant for hardware components,
747 including immutable software/firmware embedded within a hardware component.

748 **5.2.9.2 Input**

749 The following inputs shall be considered:

750 a) Architectural documentation;

751 b) Operational context.

752 **5.2.9.3 Requirements**

753 **5.2.9.3.1 [PRE-8-RQ-01]**

754 At least one mechanism shall be provided to distribute updates in a secure manner including the
755 protection of the integrity and authenticity of the update package.

756 NOTE For additional guidance on distribution of update and principle, refer to [prEN 40000-1-2:2025](#),
757 7.7.2.

758 **5.2.9.3.2 [PRE-8-RQ-02]**

759 At least one mechanism for the distribution of vulnerability information for the product shall be
760 provided.

761 **5.2.9.3.3 [PRE-8-RQ-03]**

762 Where automatic security update is applicable, a mechanism for automatic distribution shall be
763 provided. This mechanism shall include:

764 a) Processes that ensure security updates are distributed automatically with the required
765 infrastructure and design to support such a function;

766 b) An automatic process that includes checks to prevent installation during critical operations
767 and provides recovery options in the event of a failed update.

768 **5.2.9.4 Output**

769 Outputs shall include:

770 a) Documentation on the secure distribution mechanism for security updates;

771 b) Documentation on the distribution of security information;

772 c) Implementation of the distribution mechanism.

773 **5.2.9.5 Assessment criteria**

774 To demonstrate conformity to this clause the following criteria shall be met:

775 **[PRE-8-RQ-01]** (see 5.2.9.3.1)

776 a) Evidence of capability to distribute updates in a secure manner with related process and
777 implementation;

778 b) Documented appropriateness and sufficiency of the measure implemented to distribute
779 updates in a secure manner.

780 **[PRE-8-RQ-02]** (see 5.2.9.3.2)

781 c) Evidence of capability to distribute advisory messages.

782 **[PRE-8-RQ-03]** (see 5.2.9.3.3)

783 d) Evidence of capability to distribute updates, where applicable also in an automated fashion.

784 The verdict PASS is assigned if all the assessment criteria have been fulfilled.

785 **5.3 [RCP] Receipt**

786 **5.3.1 General**

787 The receipt phase establishes the activities required to ensure that vulnerability information
788 relevant to the product is collected, identified, and prepared for further analysis. Vulnerability
789 information can originate from both external sources (e.g. publicly disclosed vulnerabilities,
790 third-party reports) and internal sources (e.g. testing and review activities). In addition,
791 vulnerabilities can be reported by external stakeholders through designated reporting channels.

792 This phase ensures that:

793 — relevant vulnerability information is systematically received and monitored;

794 — collected information is prepared for impact analysis against the product's identified
795 components;

796 — potential exposure to known and previously unidentified vulnerabilities is detected at an
797 early stage.

798 By combining monitoring, report intake, and internal discovery activities, the receipt phase
799 provides the necessary inputs for determining whether the product is affected.

800 **5.3.2 [RCP-1] Capability to receive reports**

801 **5.3.2.1 General**

802 The ability to receive vulnerability reports is a fundamental capability for maintaining the
803 cybersecurity of a product throughout its life cycle. Vulnerabilities can be reported by a variety
804 of external parties, including researchers, customers, upstream stakeholders, and coordinated
805 disclosure frameworks, as well as identified internally. Without a defined and accessible
806 mechanism to receive such reports, vulnerability information might not reach the manufacturer,
807 resulting in delayed awareness and increased exposure to exploitation.

808 Establishing a structured capability to receive vulnerability reports enables the manufacturer to:

809 — ensure that externally identified vulnerabilities are communicated effectively;

- 810 — support CVD practices;
- 811 — integrate externally reported vulnerabilities into internal vulnerability handling processes.

812 Assigning an identifier, label, or tracking reference can help improve traceability of the report
 813 during on-going communications with stakeholders within the scope of vulnerability handling
 814 and disclosure activities.

815 **5.3.2.2 Input**

816 The following inputs shall be considered:

- 817 a) CVD policy (see 5.2.3).

818 **5.3.2.3 Requirements**

819 **5.3.2.3.1 [RCP-1-RQ-01]**

820 Contact mechanisms shall be provided to enable the receipt of vulnerability information or
 821 reports, in accordance with the CVD policy (see 5.2.3.3.3 [PRE-2-RQ-03] and 5.2.5.3.2 [PRE-4-RQ-
 822 02]).

823 NOTE To facilitate the verification steps of the vulnerability handling process it is important that the
 824 mechanisms for receiving the vulnerabilities can elicit information useful in assessing the validity, severity,
 825 scope, and impact of the vulnerability.

826 **5.3.2.3.2 [RCP-1-RQ-02]**

827 A mechanism shall be in place to track reported vulnerabilities.

828 NOTE The tracking mechanism can include assigning an identifier sufficient to distinguish a report
 829 from other reports (e.g. an e-mail subject, message ID, or thread reference, or a ticket number).

830 **5.3.2.3.3 [RCP-1-RQ-03]**

831 Where a communication channel has been established in accordance with 5.2.3.3.4 [PRE-2-RQ-
 832 04], and 5.2.3.3.3 [PRE-2-RQ-03] to receive vulnerability information, an acknowledgement of
 833 receipt shall be provided to the reporter or relevant stakeholders.

834 **5.3.2.3.4 [RCP-1-RQ-04]**

835 The acknowledgement as indicated in 5.3.2.3.3 [RCP-1-RQ-03], shall be delivered in alignment
 836 with the schedule defined within the CVD policy (as 5.2.3.3.4 [PRE-2-RQ-04]), and shall not
 837 exceed a maximum threshold of 7 calendar days from the receipt of the report.

838 NOTE The acknowledgement indicates that the report was delivered.

839 **5.3.2.4 Recommendation**

840 **5.3.2.4.1 [RCP-1-RC-01]**

841 A security.txt file should be published.

842 NOTE For additional guidance on the security.txt, refer to RFC 9116:2022 [\[5\]](#).

843 **5.3.2.4.2 [RCP-1-RC-02]**

844 To ensure the acknowledgement is meaningful, the response should include a unique tracking
845 number or vulnerability identifier, as established in 5.3.2.3.2 [RCP-1-RQ-02], alongside
846 preliminary status information.

847 NOTE Technical triage, validity checks, and formal severity scoring are not part of this receipt phase;
848 instead, the report is formally analysed during the verification stage in 5.4.

849 **5.3.2.4.3 [RCP-1-RC-03]**

850 A coordinator should be assigned and involved in the vulnerability handling process, where
851 appropriate.

852 **5.3.2.5 Output**

853 Outputs shall include:

- 854 a) Contact mechanisms in accordance with the CVD policy with acknowledgement receipt
855 capabilities;
- 856 b) Record of the acknowledgement response and the time at which it was sent to the reporter;
- 857 c) Mechanism to track reported vulnerabilities.

858 **5.3.2.6 Assessment criteria**

859 To demonstrate conformity to this clause the following criteria shall be met:

860 **[RCP-1-RQ-01]** (see 5.3.2.3.1)

- 861 a) Evidence of the implementation of the contact mechanisms is in accordance with the CVD
862 policy;
- 863 b) Evidence that the reporting mechanisms are working as expected.

864 **[RCP-1-RQ-02]** (see 5.3.2.3.2)

- 865 c) Evidence that reports are traceable from initial report.

866 **[RCP-1-RQ-03]** (see 5.3.2.3.3)

- 867 d) Evidence that reported vulnerabilities have an acknowledgment of receipt.

868 **[RCP-1-RQ-04]** (see 5.3.2.3.4)

- 869 e) Evidence that acknowledgement of receipt has been delivered in alignment within the
870 expected schedule.

871 The verdict PASS is assigned if all the assessment criteria have been fulfilled.

5.3.3 [RCP-2] Vulnerability Monitoring

5.3.3.1 General

Vulnerability monitoring is essential to ensure that the manufacturer maintains awareness of vulnerabilities that can affect the product throughout its life cycle. Vulnerability information originates from multiple internal and external sources and is typically generic in nature. Without systematic monitoring, relevant vulnerabilities could remain unidentified, leading to increased exposure to exploitation.

Timely and systematic monitoring ensures that newly disclosed vulnerabilities are identified early and can be assessed for their applicability to the product. Automation can support scalability and reduces delays in detection.

5.3.3.2 Input

The following inputs shall be considered:

- a) Vulnerability handling policy (as per 5.2.2);
- b) List of components (as per 5.2.6 and 5.2.7).

5.3.3.3 Requirements

5.3.3.3.1 [RCP-2-RQ-01]

Vulnerability information or reports from internal and external sources shall be monitored.

NOTE As the effectiveness of vulnerability monitoring depends on it being performed in a timely and systematic manner, the introduction of automation is suggested, where possible.

5.3.3.3.2 [RCP-2-RQ-02]

At least the following sources shall be monitored:

a) External sources

- 1) EU Vulnerability Database (EUVD);
- 2) Reported vulnerabilities (see 5.3.2);
- 3) If available, vulnerability information from component producers.

b) Internal sources

- 1) Regular testing (see 5.3.6);
- 2) Regular review (see 5.3.7).

5.3.3.4 Recommendations

5.3.3.4.1 [RCP-2-RC-01]

The list of components, identified in 5.2.6 and in 5.2.7, should be monitored for their end of support (EOS) in order to anticipate potential risks.

904 NOTE 1 For open-source components without formally defined EOS dates the maintenance status can
905 usually be assessed by considering whether the project remains actively maintained (e.g. update frequency,
906 community activity, security patching).

907 NOTE 2 Monitoring the support period of the components contained in the product supports due
908 diligence activities by anticipating potential risks arising from deprecated components and obsolete
909 technologies.

910 **5.3.3.5 Output**

911 Outputs shall include:

- 912 a) Vulnerability information;
- 913 b) List of the selected internal and external sources monitored.

914 **5.3.3.6 Assessment criteria**

915 To demonstrate conformity to this clause the following criteria shall be met:

916 **[RCP-2-RQ-01]** (see 5.3.3.3.1)

- 917 a) Evidence that the capability to monitor vulnerability information is in place;
- 918 b) Evidence of collection of vulnerability reports or information.

919 **[RCP-2-RQ-02]** (see 5.3.3.3.2)

- 920 c) Evidence of a list of internal and external sources monitored;
- 921 d) Assessment of adequacy of the sources selected.

922 The verdict PASS is assigned if all the assessment criteria have been fulfilled.

923 **5.3.4 [RCP-3] Potentially impacted software components**

924 **5.3.4.1 General**

925 Vulnerability information alone does not indicate whether a product is affected. Determining
926 impact requires a systematic comparison between vulnerability information and the software
927 components used in the product, including whether the vulnerable code is reachable and
928 exploitable. Products are typically composed of proprietary, third-party, and open-source
929 components. Vulnerabilities often target specific components and versions. Without structured
930 comparison, manufacturers cannot reliably determine whether vulnerabilities are relevant.

931 Identifying potentially impacted software components is essential to:

- 932 — ensure comprehensive vulnerability assessment covering the full product architecture;
- 933 — address risks originating from software;
- 934 — support appropriate mitigation actions.

935 This activity establishes whether the product contains software components that are potentially
936 affected by known vulnerabilities and provides the basis for subsequent verification and risk
937 assessment.

5.3.4.2 Input

The following inputs shall be considered:

- a) Vulnerability information (see 5.3.3);
- b) List of identified software components or software bill of materials (SBOM) (see 5.2.6).

5.3.4.3 Requirements

5.3.4.3.1 [RCP-3-RQ-01]

Potentially affected software components shall be identified based on vulnerability information collected from the monitoring activities (see 5.3.3).

NOTE Potentially affected components are those that can be affected by a reported but not yet verified vulnerability.

5.3.4.4 Recommendations

5.3.4.4.1 [RCP-3-RC-01]

The identification process should be automated using a machine-readable software bill of materials (SBOM) or list of components, and a machine-readable method to exchange vulnerability information.

5.3.4.5 Output

Outputs shall include:

- a) List of potentially impacted software components with related vulnerability information.

5.3.4.6 Assessment criteria

To demonstrate conformity to this clause the following criteria shall be met:

[RCP-3-RQ-01] (see 5.3.4.3.1)

- a) Evidence that identification activities have been, or can be performed.

The verdict PASS is assigned if all the assessment criteria have been fulfilled.

5.3.5 [RCP-4] Potentially impacted hardware components

5.3.5.1 General

This activity determines whether reported vulnerabilities affect hardware components used by the product, including processors, chipsets, firmware-enabled devices and other embedded hardware. The outcome supports subsequent verification and remediation activities.

Identifying potentially impacted hardware components is essential to:

- ensure comprehensive vulnerability assessment covering the full product architecture;
- address risks originating from hardware and firmware layers;

969 — support appropriate mitigation actions, which might differ from software remediation (e.g.
970 configuration changes, firmware updates, or hardware replacement).

971 This activity establishes whether the product contains hardware components that are potentially
972 affected by known vulnerabilities and provides the basis for subsequent verification and risk
973 assessment.

974 **5.3.5.2 Input**

975 The following inputs shall be considered:

976 a) Vulnerability information (see 5.3.3);

977 b) List of identified hardware components (see 5.2.7).

978 **5.3.5.3 Requirements**

979 **5.3.5.3.1 [RCP-4-RQ-01]**

980 Potentially affected hardware components shall be identified based on vulnerability information
981 collected from the monitoring activities (see 5.3.3).

982 NOTE Potentially affected components are those that can be affected by a reported but not yet verified
983 vulnerability.

984 **5.3.5.4 Output**

985 Outputs shall include:

986 a) List of potentially impacted hardware components with related vulnerability information.

987 **5.3.5.5 Assessment criteria**

988 To demonstrate conformity to this clause the following criteria shall be met:

989 **[RCP-4-RQ-01]** (see 5.3.5.3.1)

990 a) Evidence that identification activities have been, or can be performed.

991 The verdict PASS is assigned if all the assessment criteria have been fulfilled.

992 **5.3.6 [RCP-5] Performing regular tests**

993 **5.3.6.1 General**

994 Regular testing provides technical validation of the product's security posture and supports the
995 identification of vulnerabilities throughout the product life cycle. While vulnerability monitoring
996 relies on known information, testing enables the discovery of previously unknown
997 vulnerabilities, misconfiguration, and integration weaknesses. Changes in the product, including
998 updates and new components, could introduce new vulnerabilities. Regular testing ensures that
999 such vulnerabilities are identified and addressed in a timely manner. The selection of testing
1000 methods and their frequency can be based on risk-based criteria, particularly the potential impact
1001 of vulnerabilities on the product's security posture over time, as defined in 5.2.8.

1002 5.3.6.2 Input

1003 The following inputs shall be considered:

- 1004 a) Security test and review plan (see 5.2.8);
- 1005 b) Documentation about cybersecurity verification and validation.

1006 NOTE For additional guidance on cybersecurity verification and validation, refer to [prEN 40000-1-](#)
1007 [2:2025](#), 7.6.

1008 5.3.6.3 Requirements

1009 5.3.6.3.1 [RCP-5-RQ-01]

1010 Security testing shall be performed according to the security test and review plan as per 5.2.8.

1011 NOTE For additional guidance on regular security testing, refer to [prEN 40000-1-2:2025](#), 7.6.

1012 5.3.6.4 Output

1013 Outputs shall include:

- 1014 a) Security test report with its results.

1015 5.3.6.5 Assessment criteria

1016 To demonstrate conformity to this clause the following criteria shall be met:

1017 [RCP-5-RQ-01] (see 5.3.6.3.1)

- 1018 a) Evidence of security tests being performed as planned (see 5.2.8);
- 1019 b) Evidence of security test results.

1020 The verdict PASS is assigned if all the assessment criteria have been fulfilled.

1021 5.3.7 [RCP-6] Performing regular reviews

1022 5.3.7.1 General

1023 Maintaining the security of a product requires periodic reassessment of the assumptions on
1024 which its security posture is based. Over time, threats, attack techniques, and operational
1025 contexts evolve, potentially invalidating prior risk assessments. In addition, the actual use or
1026 deployment of the product can differ from the originally intended context, introducing new risks
1027 or increasing exposure.

1028 Regular reviews ensure that threat and risk assessments remain valid, and that security controls
1029 and testing activities continue to be appropriate. They complement testing activities by ensuring
1030 that the scope, assumptions, and priorities of security activities remain aligned with current
1031 conditions.

1032 5.3.7.2 Input

1033 The following inputs shall be considered:

1034 a) Security test and review plan (see 5.2.8).

1035 **5.3.7.3 Requirements**

1036 **5.3.7.3.1 [RCP-6-RQ-01]**

1037 Security reviews shall be performed according to the security test and review plan (see 5.2.8).

1038 NOTE For additional guidance on regular security reviews, refer to [prEN 40000-1-2:2025](#), 6.7.

1039 **5.3.7.4 Output**

1040 Outputs shall include:

1041 a) Security review results.

1042 **5.3.7.5 Assessment criteria**

1043 To demonstrate conformity to this clause the following criteria shall be met:

1044 **[RCP-6-RQ-01]** (see 5.3.7.3.1)

1045 a) Evidence of security review results;

1046 b) Evidence of security review being performed as planned.

1047 The verdict PASS is assigned if all the assessment criteria have been fulfilled.

1048 **5.4 [VRF] Verification**

1049 **5.4.1 General**

1050 The verification phase establishes whether a reported or identified vulnerability affects the
1051 product and determines its prioritization based on product cybersecurity risk assessment
1052 activities. Vulnerability information obtained during the receipt phase can vary in quality,
1053 completeness, and relevance. It is therefore necessary to perform a structured verification
1054 process to ensure that only valid and applicable vulnerabilities are considered for further
1055 handling.

1056 This phase ensures that:

1057 — vulnerability information is validated for accuracy and completeness;

1058 — vulnerabilities are assessed for applicability to the product, based on its identified
1059 components;

1060 — only relevant vulnerabilities proceed further in the handling process.

1061 Where a vulnerability is confirmed to be applicable, a product cybersecurity risk analysis is
1062 performed to determine:

1063 — the level of risk associated with the vulnerability;

1064 — whether mitigation is required;

1065 — the priority of remediation actions.

1066 By combining verification and risk assessment, this phase ensures that vulnerability handling
1067 activities are focused, risk-based, and efficient.

1068 Whereas 5.4.2 and 5.4.3 are separated, all the activities listed can occur in parallel rather than in
1069 a sequential order.

1070 During multi-party coordinated vulnerability (MPCVD) consider the guidance provided by
1071 [ISO/IEC TR 5895:2022](#), 9.2.

1072 **5.4.2 [VRF-1] Initial assessment**

1073 **5.4.2.1 General**

1074 Following the receipt of vulnerability information, an initial assessment and verification step is
1075 performed to determine the validity, relevance, and completeness of the information before
1076 further processing. Vulnerability information can vary in quality, accuracy, and level of detail.
1077 Reports could be incomplete, duplicated, inaccurate, or not applicable to the product. Without an
1078 initial verification step, resources could be allocated to not relevant issues, or valid vulnerabilities
1079 could not be properly understood.

1080 This activity ensures that:

- 1081 — vulnerability information is verified for correctness and authenticity;
- 1082 — sufficient information is available to support impact analysis;
- 1083 — duplicate or low-quality reports are filtered out;
- 1084 — only relevant and credible information is forwarded for further analysis.

1085 The initial assessment contributes to the efficiency and reliability of the vulnerability handling
1086 process and reduces the risk of incorrect or delayed decisions.

1087 **5.4.2.2 Input**

1088 The following inputs shall be considered:

- 1089 a) Vulnerability information (see 5.3.3);
- 1090 b) List of software and hardware components (see 5.2.6 and 5.2.7);
- 1091 c) Product context;
- 1092 d) Product security risk assessment;
- 1093 e) Cybersecurity architecture and design.

1094 NOTE References to the inputs can be found for:

- 1095 — Product context in [prEN 40000-1-2:2025](#), 6.2;
- 1096 — Product cybersecurity risk assessment in [prEN 40000-1-2:2025](#), 6.4;
- 1097 — Cybersecurity architecture and design in [prEN 40000-1-2:2025](#), 7.4.

1098 **5.4.2.3 Requirements**

1099 **5.4.2.3.1 [VRF-1-RQ-01]**

1100 An initial assessment of the potential vulnerability shall be performed to evaluate the validity,
1101 relevance and reported severity.

1102 NOTE 1 The decision to remediate a vulnerability can pre-empt a full assessment.

1103 NOTE 2 It is possible to address and assess a group of vulnerabilities as a bulk.

1104 **5.4.2.3.2 [VRF-1-RQ-02]**

1105 When the initial assessment results in exiting the vulnerability handling process, this decision
1106 shall be justified and documented.

1107 NOTE Acceptable justifications for exiting the vulnerability handling process can include and are not
1108 limited to the following:

1109 a) Non-verifiable or non-reproducible vulnerabilities

1110 1) If a vulnerability cannot be verified or reproduced, additional information can be requested.

1111 2) If sufficient information is not provided, or verification remains unsuccessful, the outcome can be
1112 documented and the process to be terminated.

1113 b) Duplicate vulnerabilities

1114 1) If a vulnerability is identified as a duplicate of an already reported or known vulnerability, the
1115 report can be linked to the existing case, and avoid duplicate handling.

1116 c) Not part of the product context, non-security or non-exploitable issues

1117 1) If an issue is determined not part of the product context, not to be a security vulnerability or not
1118 exploitable, the assessment and justification can be documented.

1119 2) Such cases can be considered for monitoring, as exploitability can change over time, and, where
1120 appropriate, included in test and review plan as 5.2.8 and in the testing and review activities.

1121 **5.4.2.3.3 [VRF-1-RQ-03]**

1122 When the vulnerability is in a third-party component (see 5.2.6.3.2 [PRE-5-RQ-2]) and the
1123 vulnerability is fully mitigated by a remediation, and the remediation is applied, all the
1124 requirements shall be applied, except for the following unless deemed necessary:

1125 a) 5.4.3.3.1 [VRF-2-RQ-01];

1126 b) 5.4.3.3.2 [VRF-2-RQ-02];

1127 c) 5.4.3.3.3 [VRF-2-RQ-03];

1128 d) 5.4.3.3.4 [VRF-2-RQ-04];

1129 e) 5.5.2.3.1 [RMD-1-RQ-01];

1130 f) 5.5.2.3.2 [RMD-1-RQ-02].

1131 NOTE If for instance a remediation is fully mitigating a vulnerability in a third-party component then
 1132 certain activities are not required if this remediation is applied, but if desired all steps still can be executed.

1133 **5.4.2.4 Recommendations**

1134 **5.4.2.4.1 [VRF-1-RC-01]**

1135 A root cause analysis should at least be performed and documented for the components identified
 1136 (see 5.2.6.3.1 [PRE-5-RQ-01]). The analysis should include:

- 1137 a) identification of the underlying cause of the vulnerability;
- 1138 b) identification of affected products or components;
- 1139 c) identification and description of relevant exploitation conditions or methods, where
 1140 applicable.

1141 NOTE Root cause analysis is not required for all vulnerabilities and is intended for selected cases, for
 1142 example, those with high severity and/or repeated occurrence. The outcome can be used to support:

- 1143 — remediation activities (see 5.5);
- 1144 — vulnerability risk assessment (see 5.4.3);
- 1145 — prevention of recurrence through testing and review activities (see 5.2.8);
- 1146 — improvement to the secure software development lifecycle (see 5.7.2).

1147 **5.4.2.4.2 [VRF-1-RC-02]**

1148 For selected vulnerabilities, further investigation should be performed to identify other potential
 1149 occurrences of the same type of vulnerability.

1150 **5.4.2.5 Output**

1151 Outputs shall include:

- 1152 a) Verified vulnerability report;
- 1153 b) Vulnerability report status updates;
- 1154 c) Rejected or invalid vulnerability report with justification.

1155 **5.4.2.6 Assessment criteria**

1156 To demonstrate conformity to this clause the following criteria shall be met:

1157 **[VRF-1-RQ-01]** (see 5.4.2.3.1)

- 1158 a) Evidence exists that reported vulnerabilities are assessed for validity, relevance and severity;
- 1159 b) Evidence exists that a decision has been made on whether the issue qualifies as a
 1160 vulnerability;
- 1161 c) Evidence exists that the status of the vulnerability report is recorded and updated.

1162 **[VRF-1-RQ-02]** (see 5.4.2.3.2)

1163 d) Evidence exists that decisions to terminate the process are justified and traceable.

1164 **[VRF-1-RQ-03]** (see 5.4.2.3.3)

1165 e) Evidence that the vulnerability is fully mitigated by the applied remediation.

1166 The verdict PASS is assigned if all the assessment criteria have been fulfilled.

1167 **5.4.3 [VRF-2] Vulnerability risk assessment**

1168 **5.4.3.1 General**

1169 Following the initial assessment of vulnerability information, a detailed risk assessment is
1170 performed to determine the potential impact and urgency of remediation. While initial
1171 classification can provide a preliminary indication of severity, it does not fully reflect the specific
1172 context of the product, including its architecture, usage, exposure, and operational environment.
1173 A refined risk assessment ensures that vulnerabilities are evaluated in relation to the actual risk
1174 they pose to the product and its assets.

1175 This activity enables the manufacturer to:

1176 — assess the likelihood and potential impact of exploitation within the product context;

1177 — prioritize remediation actions based on risk rather than generic severity scores;

1178 — ensure consistent and justified decision-making in vulnerability handling.

1179 The cybersecurity risk assessment is performed in accordance with the product's established risk
1180 management framework, ensuring that results are consistent with the overall risk evaluation
1181 methodology applied to the product. This promotes alignment between vulnerability handling
1182 and broader product risk management practices.

1183 It is important to note that a vulnerability can affect different components with different types of
1184 severity. So, in this phase, it is important to consider product issues, focusing on the most common
1185 operating conditions and deployment scenarios that can support prioritization.

1186 For guidance related to an example of a risk management framework that can be referred is [prEN](#)
1187 [40000-1-2:2025](#)

1188 **5.4.3.2 Input**

1189 The following inputs shall be considered:

1190 a) Verified vulnerability report (see 5.4.2);

1191 b) Product security risk assessment.

1192 NOTE for additional information related to product security risk assessment see for example [prEN](#)
1193 [40000-1-2:2025](#), 6.4.

1194 **5.4.3.3 Requirements**

1195 **5.4.3.3.1 [VRF-2-RQ-01]**

1196 The risk introduced by the vulnerability shall be assessed including the severity in accordance
1197 with the product security risk assessment.

- 1198 NOTE 1 It is possible to address and assess a group of vulnerabilities as a bulk.
- 1199 NOTE 2 For additional information related to product security risk assessment see for example [prEN](#)
1200 [40000-1-2:2025](#), 6.4.
- 1201 **5.4.3.3.2 [VRF-2-RQ-02]**
- 1202 The priority shall be assigned to the vulnerability based on the outcome of 5.4.3.3.1 [VRF-02-RQ-
1203 01] in order to determine the urgency and scope of the subsequent remediation activities.
- 1204 **5.4.3.3.3 [VRF-2-RQ-03]**
- 1205 Where the assigned priority indicates a need for accelerated handling, remediation activities shall
1206 be performed on an expedited basis.
- 1207 **5.4.3.3.4 [VRF-2-RQ-04]**
- 1208 Where vulnerability information is received via coordinated disclosure, the reporter and relevant
1209 stakeholders shall be informed of the outcome of the verification (see 5.2.5). The communication
1210 shall include:
- 1211 a) the verification outcome;
- 1212 b) justification for decisions, including termination where relevant.
- 1213 **5.4.3.4 Output**
- 1214 Outputs shall include:
- 1215 a) Verified vulnerability report (see 5.4.2) with the additional required information (see 5.4.3);
- 1216 b) Assigned priority level for the vulnerability;
- 1217 c) Recorded decision on whether expedited handling is applied;
- 1218 d) Communication records reflecting notification of the verification results to the reporter and
1219 other relevant stakeholders.
- 1220 **5.4.3.5 Assessment criteria**
- 1221 To demonstrate conformity to this clause the following criteria shall be met:
- 1222 **[VRF-2-RQ-01]** (see 5.4.3.3.1)
- 1223 a) Evidence exists that the risk of each verified vulnerability is assessed in accordance with the
1224 product cybersecurity risk assessment framework;
- 1225 b) Evidence of the determination of severity of the vulnerability.
- 1226 **[VRF-2-RQ-02]** (see 5.4.3.3.2)
- 1227 c) Evidence exists that a priority level is assigned to each verified vulnerability based on the
1228 vulnerability risk assessment;
- 1229 d) Evidence exists that prioritization decisions are documented and traceable.

1230 **[VRF-2-RQ-03]** (see 5.4.3.3.3)

1231 e) Evidence exists that criteria for expedited handling are applied.

1232 **[VRF-2-RQ-4]** (see 5.4.3.3.4)

1233 f) Evidence exists that communication with reporters and other relevant stakeholders is
1234 updated with the outcome of the verification process.

1235 The verdict PASS is assigned if all the assessment criteria have been fulfilled.

1236 **5.5 [RMD] Remediation**

1237 **5.5.1 General**

1238 The remediation phase defines the activities required to reduce or eliminate cybersecurity risks
1239 associated with verified vulnerabilities. Following verification and risk assessment, appropriate
1240 remediation actions are identified, developed, and prepared for deployment. These actions might
1241 include corrective measures, mitigations, or compensating controls, depending on the nature of
1242 the vulnerability and the product context. This phase ensures that:

- 1243 — appropriate remediation measures are identified and selected based on the assessed risk;
- 1244 — remediation activities are planned, implemented, and validated for effectiveness and
1245 compatibility;
- 1246 — updates or mitigation measures are prepared for distribution and deployment;
- 1247 — residual risks are appropriately managed, where full remediation is not immediately feasible.

1248 Remediation activities could involve coordination with multiple stakeholders, including
1249 maintainers, and other external parties. In such cases, coordinated handling of vulnerabilities is
1250 essential to ensure consistent and effective resolution across affected components and systems.

1251 During multi-party coordinated vulnerability disclosure (MPCVD) consider the guidance
1252 provided by [ISO/IEC TR 5895:2022](#), 9.3.

1253 **5.5.2 [RMD-1] Remediation decision**

1254 **5.5.2.1 General**

1255 Following the verification of vulnerabilities, decisions are taken to determine how cybersecurity
1256 risks can be addressed in the context of the product.

1257 The remediation decision phase establishes the activities to select appropriate measures to
1258 mitigate identified cybersecurity risks, taking into account the characteristics of the vulnerability,
1259 the product context, and the results of the risk assessment.

1260 Vulnerabilities can imply different types of responses, including corrective updates, mitigation
1261 measures, or other risk treatment options. The selection of an appropriate response considers
1262 technical feasibility, effectiveness, impact on the product, and potential consequences for users
1263 and other stakeholders.

1264 This phase ensures that remediation decisions are:

- 1265 — consistent with the product cybersecurity risk assessment framework;
- 1266 — proportionate to the assessed risk and prioritization;
- 1267 — based on a structured evaluation of available remediation options;
- 1268 — not negatively impact product functionality, performance, or compatibility.

1269 **5.5.2.2 Input**

1270 The following inputs shall be considered:

- 1271 a) Verified vulnerability with output of its risk assessment (see 5.4.3).

1272 **5.5.2.3 Requirements**

1273 **5.5.2.3.1 [RMD-1-RQ-01]**

1274 A decision shall be made whether to remediate a verified vulnerability, based on:

- 1275 a) the results of the vulnerability risk assessment (see 5.4.3);
- 1276 b) the assigned priority (see 5.4.3).

1277 **5.5.2.3.2 [RMD-1-RQ-02]**

1278 Where a decision is made not to remediate a vulnerability, or to defer remediation, the decision
1279 shall be justified and documented. The justification shall consider:

- 1280 a) the assessed risk and its acceptability;
- 1281 b) the presence of mitigating controls or compensating measures;
- 1282 c) technical or operational constraints;
- 1283 d) potential impact on the product, users, or stakeholders.

1284 **5.5.2.3.3 [RMD-1-RQ-03]**

1285 Where a decision is made to remediate a vulnerability, an appropriate remediation approach shall
1286 be selected. The selected approach shall consider:

- 1287 a) implementation of a corrective update, or other remediation measures;
- 1288 b) application of temporary mitigation measures;
- 1289 c) coordination with external stakeholders or dependencies;
- 1290 d) feasibility and effectiveness of the remediation measures;
- 1291 e) the urgency of remediation in relation to the assessed risk, including known or potential
1292 exploitation conditions;
- 1293 f) the balance between timely deployment and adequate testing to avoid negative impact on
1294 product functionality or users.

1295 **5.5.2.3.4 [RMD-1-RQ-04]**

1296 In accordance with the remediation approach selected, subsequent remediation actions shall be
1297 defined and planned, including the definition of the related timelines.

1298 NOTE In cases of MPCVD, the involvement of additional stakeholders can influence the timelines due
1299 to dependencies and coordination needs.

1300 **5.5.2.4 Output**

1301 Outputs shall include:

1302 a) Documented decision about the remediation;

1303 b) Where remediation is deferred or not performed, a documented justification;

1304 c) A documented decision on how the vulnerability will be remediated, where remediation is
1305 decided;

1306 d) A documented remediation plan, including defined timelines, where remediation is decided.

1307 **5.5.2.5 Assessment criteria**

1308 To demonstrate conformity to this clause the following criteria shall be met:

1309 **[RMD-1-RQ-01]** (see 5.5.2.3.1)

1310 a) Evidence exists that a decision is made for verified vulnerability, where remediation is
1311 required.

1312 **[RMD-1-RQ-02]** (see 5.5.2.3.2)

1313 b) Evidence of a justification when the decision is not to remediate or to defer the remediation.

1314 **[RMD-1-RQ-03]** (see 5.5.2.3.3)

1315 c) Evidence exists that a remediation approach is defined, where remediation is decided.

1316 **[RMD-1-RQ-04]** (see 5.5.2.3.4)

1317 d) Evidence exists that remediation actions are defined and planned, where remediation is
1318 decided.

1319 The verdict PASS is assigned if all the assessment criteria have been fulfilled.

1320 **5.5.3 [RMD-2] Remediation development**

1321 **5.5.3.1 General**

1322 Following the remediation decision and planning (see 5.5.2) activities are performed to develop
1323 and implement remediation measures to reduce or eliminate the cybersecurity risks associated
1324 with identified vulnerabilities.

1325 Remediation activities can involve the creation or integration of corrective updates, mitigation
1326 measures, configuration changes, documentation or other technical controls, depending on the
1327 selected remediation approach. These activities ensure that the identified vulnerability is

1328 effectively addressed without introducing additional risks or negatively impacting the product or
1329 its operational environment.

1330 This phase ensures that:

- 1331 — remediation measures are implemented in accordance with the defined remediation plan;
- 1332 — remediation actions are technically effective and compatible with the product context;
- 1333 — potential side effects or regressions are identified and minimized;
- 1334 — dependencies on third-party components or external stakeholders are appropriately
1335 managed.

1336 Remediation activities might involve coordination with multiple parties, including upstream
1337 stakeholders such as maintainers, and open-source communities, particularly where
1338 vulnerabilities affect shared components or external dependencies.

1339 **5.5.3.2 Input**

1340 The following inputs shall be considered:

- 1341 a) Documented decision about the remediation (see 5.5.2);
- 1342 b) A documented remediation plan, including defined timelines, where remediation is required
1343 (see 5.5.2).

1344 **5.5.3.3 Requirements**

1345 **5.5.3.3.1 [RMD-2-RQ-01]**

1346 Remediation measures shall be implemented in accordance with the defined remediation plan
1347 (see 5.5.2). The implementation shall ensure that:

- 1348 a) the identified vulnerability is effectively addressed;
- 1349 b) remediation measures are consistent with the selected remediation approach;
- 1350 c) remediation activities are aligned with defined timelines and priorities.

1351 NOTE 1 Remediation measures can include updates, configuration changes, documentation changes, or
1352 other artefacts that address the vulnerability.

1353 NOTE 2 Remediation development leverage internal development and maintenance processes (e.g. as
1354 described in [prEN 40000-1-2:2025](#), 7).

1355 **5.5.3.3.2 [RMD-2-RQ-02]**

1356 Remediation measures shall be limited to the necessary changes required to address the
1357 vulnerability from a security perspective without including functionality changes, where
1358 technically feasible. Where this is not feasible, it shall be justified and documented.

1359 EXAMPLE Justification can include, for example:

- 1360 — architectural constraints preventing the separation of changes;

- 1361 — maintainability considerations;
- 1362 — safety or regulatory constraints;
- 1363 — user or system deployment requirements;
- 1364 — disproportionate impact on performance or stability;
- 1365 — constraints related to update or release processes.

1366 **5.5.3.4 Output**

1367 Outputs shall include:

- 1368 a) Produced remediations and related documentation;
- 1369 b) Documented justification, where remediation measures implemented include functionality
1370 changes to address the vulnerability.

1371 **5.5.3.5 Assessment criteria**

1372 To demonstrate conformity to this clause the following criteria shall be met:

1373 **[RMD-2-RQ-01]** (see 5.5.3.3.1)

- 1374 a) Evidence of a produced remediation and related documentation.

1375 **[RMD-2-RQ-02]** (see 5.5.3.3.2)

- 1376 b) Evidence of justification when security updates cannot be implemented separately from
1377 functionality updates.

1378 The verdict PASS is assigned if all the assessment criteria have been fulfilled.

1379 **5.5.4 [RMD-3] Remediation test**

1380 **5.5.4.1 General**

1381 Following the implementation of remediation measures (see 5.5.3), testing and validation
1382 activities are performed to ensure that the remediation effectively mitigates the identified
1383 vulnerability and does not introduce unintended effects that could impact the product.

1384 Remediation measures can affect multiple components, system interactions, or operational
1385 environments. Without appropriate testing and validation, implemented remediation can fail to
1386 fully address the vulnerability, introduce new defects or vulnerabilities, or negatively impact
1387 product functionality, performance, or compatibility.

1388 This phase ensures that:

- 1389 — remediation measures are verified to effectively address the identified vulnerability;
- 1390 — remediation does not introduce new vulnerabilities, defects, or regressions;
- 1391 — remediation is compatible with the product architecture, interfaces, and operational context;
- 1392 — unintended effects are acceptable.

1393 Testing and validation activities can include different levels of verification, such as functional
 1394 testing, security testing, regression testing, or compatibility testing, depending on the nature of
 1395 the remediation and the product context.

1396 **5.5.4.2 Input**

1397 The following inputs shall be considered:

- 1398 a) Remediation plan, including the timeline (see 5.5.2);
- 1399 b) Decision on remediation of the vulnerability (see 5.5.2);
- 1400 c) Produced remediation and related documentation (see 5.5.3);
- 1401 d) Test and review plan (see 5.2.8).

1402 **5.5.4.3 Requirements**

1403 **5.5.4.3.1 [RMD-3-RQ-01]**

1404 The remediation shall be tested to ensure it addresses the vulnerability(ies).

1405 **5.5.4.3.2 [RMD-3-RQ-02]**

1406 Unintended effects shall be assessed for acceptability.

1407 EXAMPLE Unintended effects can include, for example, degradation of performance, restrictions in
 1408 functionality, or limitations in usage.

1409 **5.5.4.3.3 [RMD-3-RQ-03]**

1410 Where remediation measures originate from third parties, they shall be validated within the
 1411 product context, to the extent reasonably practical, to ensure that:

- 1412 a) the vulnerability is effectively addressed at the product level;
- 1413 b) the remediation is compatible with the product architecture, configuration, and operational
 1414 environment.

1415 **5.5.4.4 Output**

1416 Outputs shall include:

- 1417 a) A documented test and validation report;
- 1418 b) Validated remediation artefacts;
- 1419 c) Where remediation originates from third parties, a documented validation report, where
 1420 applicable.

1421 **5.5.4.5 Assessment criteria**

1422 To demonstrate conformity to this clause the following criteria shall be met:

1423 **[RMD-3-RQ-01]** (see 5.5.4.3.1)

1424 a) Evidence that test and validation activities are performed, as documented in the remediation
1425 test and validation report.

1426 **[RMD-3-RQ-02]** (see 5.5.4.3.2)

1427 b) Evidence that identified effects during the testing have been assessed and accepted.

1428 **[RMD-3-RQ-03]** (see 5.5.4.3.3)

1429 c) Where applicable, evidence that third-party remediation is validated within the product
1430 context.

1431 The verdict PASS is assigned if all the assessment criteria have been fulfilled.

1432 **5.6 [RLS] Release**

1433 **5.6.1 General**

1434 Following the testing and validation of remediation measures (see 5.5.4), the release phase
1435 establishes the activities to make remediation measures available to relevant stakeholders and
1436 to ensure that associated information is communicated in a clear and consistent manner.

1437 Remediation measures, including updates, patches, or mitigations, need to be disseminated in a
1438 controlled and timely manner to reduce the exposure of products and users to identified
1439 vulnerabilities. Inadequate or inconsistent release of remediation could delay deployment,
1440 increase the window of exploitation, or lead to misinterpretation of remediation actions.

1441 This phase ensures that:

1442 — remediation measures are made available for deployment in accordance with defined
1443 processes and timelines;

1444 — relevant stakeholders are informed of available remediation and associated impacts;

1445 — information related to remediation is accurate, complete, and consistent, supporting correct
1446 implementation by users;

1447 — dependencies on external stakeholders and coordinated disclosure processes are
1448 appropriately managed.

1449 **5.6.2 [RLS-1] Security update release**

1450 **5.6.2.1 General**

1451 Following the validation of remediation measures (see 5.5.4), activities are performed to prepare
1452 and release remediation artefacts and to ensure that they are securely and efficiently distributed
1453 to relevant stakeholders.

1454 Timely release of remediation measures is essential to reduce the exposure of products and users
1455 to identified vulnerabilities. Delays in releasing security updates could increase the likelihood of
1456 exploitation and extend the exposure window.

1457 This phase ensures that:

1458 — remediation artefacts are collected, prepared, and made available for deployment;

- 1459 — remediation measures are distributed in a timely and secure manner;
- 1460 — mechanisms are in place to ensure the integrity and authenticity of updates;
- 1461 — stakeholders receive sufficient and accurate information to apply the remediation;
- 1462 — dependencies on product context, deployment models, and stakeholder coordination are
- 1463 appropriately considered.

1464 Remediation measures are distributed automatically or manually depending on the product
1465 characteristics, technical implementation, intended use, and operational context.

1466 **5.6.2.2 Input**

1467 The following inputs shall be considered:

- 1468 a) Tested security update or remediation as required (see 5.5.4):
- 1469 b) Produced remediation and related documentation (see 5.5.3);
- 1470 c) Remediation plan, including the timeline (see 5.5.2);
- 1471 d) Secure distribution mechanism for security updates (see 5.2.9).

1472 **5.6.2.3 Requirements**

1473 **5.6.2.3.1 [RLS-1-RQ-01]**

1474 **[RLS-1-RQ-01]** Security updates shall be provided, unless otherwise agreed between a
1475 manufacturer and a business user in relation to a tailor-made product with a digital element, free
1476 of charge.

1477 **5.6.2.3.2 [RLS-1-RQ-02]**

1478 Once a security update is available, it shall be distributed in a timely manner, taking into account:

- 1479 a) the assigned priority and urgency (see 5.4.3);
- 1480 b) the defined remediation timelines (see 5.5.2).

1481 NOTE 1 Expedited distribution of remediation can be required for critical vulnerabilities.

1482 NOTE 2 For additional guidance on the distribution, refer to [prEN 40000-1-2:2025](#), 7.7.

1483 **5.6.2.3.3 [RLS-1-RQ-03]**

1484 Where security updates are not fully automated, appropriate installation and deployment
1485 instructions shall be available for the party responsible for deploying the update, taking into
1486 account the product context to enable correct and effective application of the update.

1487 **5.6.2.4 Output**

1488 Outputs shall include:

- 1489 a) Distributed security updates, including updates, patches, or mitigation measures made
- 1490 available to stakeholders;

- 1491 b) Recording of the timely release and availability of the distributed security updates;
- 1492 c) Installation and deployment instructions, where applicable, including information necessary
- 1493 for the correct application of the security update.

1494 **5.6.2.5 Assessment criteria**

1495 To demonstrate conformity to this clause the following criteria shall be met:

1496 **[RLS-1-RQ-01]** (see 5.6.2.3.1)

1497 a) Evidence exists that security updates are provided and made available to stakeholders;

1498 b) Where applicable, evidence exists that agreements with business users justify deviations.

1499 **[RLS-1-RQ-02]** (see 5.6.2.3.2)

1500 c) Evidence exists that security updates are distributed in accordance with defined timelines;

1501 d) Evidence exists that distribution reflects the assigned priority and remediation timelines.

1502 **[RLS-1-RQ-03]** (see 5.6.2.3.3)

1503 e) Where updates are not fully automated, evidence exists that installation and deployment

1504 instructions are provided;

1505 f) Where no instructions are provided, evidence exists that distribution is fully automated and

1506 does not require user intervention.

1507 The verdict PASS is assigned if all the assessment criteria have been fulfilled.

1508 **5.6.3 [RLS-2] Release information**

1509 **5.6.3.1 General**

1510 Following the release of remediation measures (see 5.6.2), activities are required to publish and

1511 communicate information about vulnerabilities and the corresponding remediation measures to

1512 relevant stakeholders.

1513 Clear, accurate, and timely communication of vulnerability information is essential to enable

1514 stakeholders to understand the nature of vulnerabilities, assess associated risks, and take

1515 appropriate actions, including the application of available remediation measures.

1516 Publications such as advisories, release notes, or other communication artefacts provide

1517 structured and consistent information regarding vulnerabilities, affected products, remediation

1518 status, and any required stakeholder actions. These communications also support coordinated

1519 handling of vulnerabilities involving external parties.

1520 This phase ensures that:

1521 — information about vulnerabilities and remediation measures is communicated in a clear,

1522 accurate, and consistent manner;

1523 — stakeholders are informed of relevant risks, available remediation, and required actions;

- 1524 — communication is aligned with CVD practices (see 5.2.3);
- 1525 — published information supports correct understanding and effective mitigation of risks;
- 1526 — dependencies involving external stakeholders and multi-party coordination are
- 1527 appropriately addressed.

1528 **5.6.3.2 Input**

1529 The following inputs shall be considered:

- 1530 a) Validated remediation as required (see 5.5.4);
- 1531 b) CVD policy (see 5.2.3);
- 1532 c) Vulnerability information, including description, affected components, and relevant technical
- 1533 details. (see 5.4.2);
- 1534 d) Vulnerability risk assessment results, including impact, severity, and prioritization (see
- 1535 5.4.3).

1536 **5.6.3.3 Requirements**

1537 **5.6.3.3.1 [RLS-2-RQ-01]**

1538 Information on vulnerabilities shall be published in accordance with the CVD policy (see 5.2.3).

1539 NOTE The publication of advisory is expected to align with the agreed embargo period.

1540 **5.6.3.3.2 [RLS-2-RQ-02]**

1541 For vulnerabilities affecting non third-party components integrated in the product the published

1542 advisory shall include:

- 1543 a) a description of the vulnerability;
- 1544 b) identifiers such as:
 - 1545 1) advisory identifier(s), where applicable;
 - 1546 2) vulnerability identifier(s) (e.g. CVE), where available;
 - 1547 3) product identifier(s) allowing the identification of the affected product;
- 1548 c) date of initial advisory publication and subsequent revisions;
- 1549 d) title of published information with related overview, where applicable;
- 1550 e) intended audience, where applicable;
- 1551 f) potential impact of the vulnerability;
- 1552 g) severity of the vulnerability;
- 1553 h) information on available remediation measures;

1554 i) guidance on actions required to mitigate the vulnerability, where applicable;

1555 j) contact information.

1556 NOTE The information can be aggregated and summarized, e.g. in an advisory when same
1557 vulnerability affects multiple products or when multiple vulnerabilities have been addressed by the same
1558 remediation.

1559 **5.6.3.3.3 [RLS-2-RQ-03]**

1560 For vulnerabilities affecting third-party components integrated in the product the published
1561 advisory shall include:

1562 a) reference the third-party publication on vulnerability information or;

1563 b) reference to the updated version or;

1564 c) sufficient detail to support stakeholders to determine the relevance of the vulnerability.

1565 NOTE This information can usually be found in the website of the upstream stakeholder.

1566 **5.6.3.3.4 [RLS-2-RQ-04]**

1567 Information regarding vulnerabilities addressed by the remediation shall be made available in an
1568 accessible format (see 5.2.5.3.2 [PRE-4-RQ-02]).

1569 **5.6.3.3.5 [RLS-2-RQ-05]**

1570 Information regarding vulnerabilities addressed by the remediation shall be made available in a
1571 widely recognized machine-readable format, unless a justification is provided and documented.

1572 NOTE An example of such a machine-readable format is specified in [ISO/IEC 20153:2025](#).

1573 **5.6.3.3.6 [RLS-2-RQ-06]**

1574 If the following conditions apply:

1575 a) an evaluation determines that the risks of full publication outweigh the security benefits; and

1576 b) product users are adequately informed about the date of public disclosure of all vulnerability
1577 information;

1578 in order to give sufficient time to develop and apply the remediation, it shall be possible to delay
1579 the publication of vulnerability information addressed by this remediation according to 5.6.3.3.2
1580 [RLS-2-RQ-02].

1581 **5.6.3.3.7 [RLS-2-RQ-07]**

1582 Information on the vulnerabilities addressed by the remediation shall be published except when
1583 all the following conditions apply:

1584 a) the vulnerabilities have been fully remediated;

1585 b) deployment of the remediation is under the control of the manufacturer;

1586 c) no residual risk remains for users that would require awareness or action on their part;

1587 d) the vulnerabilities only apply to and are fully remediated in the remote data processing
1588 solution.

1589 **5.6.3.4 Output**

1590 Outputs shall include:

- 1591 a) Publicly disclosed information on vulnerabilities addressed by the remediation;
- 1592 b) Documented rationale for delaying publication of vulnerability information, where
1593 applicable;
- 1594 c) Planned publication date for delayed disclosure, where applicable;
- 1595 d) Documented rationale on the use of non-supported machine-readable format, where
1596 applicable.

1597 **5.6.3.5 Assessment criteria**

1598 To demonstrate conformity to this clause the following criteria shall be met:

1599 **[RLS-2-RQ-01]** (see 5.6.3.3.1)

- 1600 a) Evidence that information of vulnerabilities addressed by the remediation is published
1601 unless the conditions of 5.6.3.3.6 [RLS-2-RQ-06] or 5.6.3.3.7 [RLS-2-RQ-07] are met.

1602 **[RLS-2-RQ-02]** (see 5.6.3.3.2)

- 1603 b) Evidence that listed information is provided for publication.

1604 **[RLS-2-RQ-03]** (see 5.6.3.3.3)

- 1605 c) Evidence that listed information is provided for publication.

1606 **[RLS-2-RQ-04]** (see 5.6.3.3.4)

- 1607 d) Evidence that publication format is accessible.

1608 **[RLS-2-RQ-05]** (see 5.6.3.3.5)

- 1609 e) Evidence that publication format follows a widely recognized machine-readable format, or
1610 justification exists.

1611 **[RLS-2-RQ-06]** (see 5.6.3.3.6)

- 1612 f) Evaluation determines the risks of full publication outweighs the security benefits;

- 1613 g) Evidence of announced date to publish information.

1614 **[RLS-2-RQ-07]** (see 5.6.3.3.7)

- 1615 h) Evidence that conditions listed are met when information on the vulnerabilities is not
1616 published.

1617 The verdict PASS is assigned if all the assessment criteria have been fulfilled.

1618 **5.7 [PRA] Post-release activities**

1619 **5.7.1 General**

1620 The phase addresses activities that are performed after vulnerability remediation measures have
1621 been released and deployed. The completion of remediation activities does not necessarily
1622 conclude vulnerability handling. Additional actions are performed to maintain remediation
1623 effectiveness, address newly identified information, evaluate the impact of deployed remediation
1624 measures, and support continuous improvement of product security and related processes.

1625 This phase helps ensure that vulnerability handling remains effective throughout the life cycle of
1626 the product.

1627 **5.7.2 [PRA-1] Post-release actions**

1628 **5.7.2.1 General**

1629 Post-release actions support the continued effectiveness of remediation measures and help
1630 ensure that lessons learned during vulnerability handling are incorporated into product and
1631 service development and maintenance activities.

1632 The effectiveness of remediation measures needs to be assessed after release. Additional
1633 improvements, corrections, or updates can be identified through operational experience,
1634 stakeholder feedback, monitoring activities, or newly available information related to the
1635 vulnerability.

1636 Maintaining vulnerability cases after remediation release helps ensure that vulnerability
1637 handling activities remain accurate and appropriate over time.

1638 Information obtained during root cause analysis can provide valuable insights into weaknesses
1639 in development, integration, testing, or maintenance processes. Incorporating these lessons into
1640 the development life cycle can help reduce the likelihood of similar vulnerabilities occurring in
1641 future products or updates.

1642 This phase ensures that:

- 1643 — released remediation measures continue to be maintained and improved where necessary;
- 1644 — additional remediation actions can be identified and addressed following release;
- 1645 — lessons learned from vulnerability handling activities are used to improve development and
1646 maintenance practices;
- 1647 — recurring vulnerabilities resulting from common root causes are reduced;
- 1648 — the stability and effectiveness of deployed remediation measures are monitored, where
1649 applicable.

1650 **5.7.2.2 Input**

1651 The following inputs shall be considered:

- 1652 a) Verified vulnerability report (see 5.4.3);
- 1653 b) Documented outcome of the vulnerability prioritization activity (see 5.4.3);

1654 c) Validated remediation artefacts and related documentation (see 5.5.4).

1655 **5.7.2.3 Requirements**

1656 **5.7.2.3.1 [PRA-1-RQ-01]**

1657 Post-release actions shall be considered, including:

- 1658 a) case maintenance;
- 1659 b) monitoring of remediation;
- 1660 c) update the development activities, where applicable.

1661 NOTE

- 1662 — case maintenance refers to continue to manage the vulnerability case after the remediation is released.
1663 If further improvements or corrections are needed, update the remediation and repeat relevant
1664 activities, such as verification or remediation development.
- 1665 — monitoring of remediation is used after applying the remediation for a vulnerability to ensure it
1666 remains effective and stable.
- 1667 — update the development activities using the lessons learned helps prevent similar vulnerabilities in
1668 new or updated products.

1669 **5.7.2.4 Output**

1670 Outputs shall include:

- 1671 a) Documentation of post-release actions.

1672 **5.7.2.5 Assessment criteria**

1673 To demonstrate conformity to this clause the following criteria shall be met:

1674 **[PRA-1-RQ-01]** (see 5.7.2.3.1)

- 1675 a) Evidence exists that the documentation of post-release actions exists and includes evidence
1676 of the applicable activities performed.

1677 The verdict PASS is assigned if all the assessment criteria have been fulfilled.

Annex A (informative)

Mapping of vulnerability handling activities to identified risks

This annex provides an informative mapping between the vulnerability handling activities specified in Clause 5 of this document and the cybersecurity risks that each activity is intended to mitigate. For each normative sub-clause, Table A.1 describes the general risks that could materialize if the corresponding activity is not implemented - for example, increased exposure to exploitation, delayed or ineffective remediation, or loss of stakeholder trust.

This mapping is provided to support the understanding of the general risks addressed by each underlying activity.

Table A.1 — Risk Mapping Table

Section of this document	Description of the risk mitigated
5.2.2	Failure to establish a vulnerability handling policy can lead to fragmented processes, inconsistent decisions, a lack of accountability, and an ineffective remediation of the vulnerability.
5.2.3	Failure to establish a coordinated disclosure policy can lead to premature disclosure, inadequate communication, and increased risk to users and other affected parties.
5.2.4	Failure to maintain appropriate confidentiality can result in premature disclosure of vulnerability information, increased likelihood of exploitation, disruption of coordinated remediation activities, and increased cybersecurity risks for affected products, users, and stakeholders.
5.2.5	Failure to maintain appropriate communication can lead to fragmented handling, delayed responses, misalignment between stakeholders, and increased risk.
5.2.6	Failing to identify and maintain information about software components can lead to undetected vulnerabilities, incomplete investigations, and greater exposure to cybersecurity risks.
5.2.7	Failure to identify and maintain hardware component information can lead to undetected vulnerabilities, incomplete investigations, and increased exposure to cybersecurity risks.
5.2.8	Failure to define and maintain test and review plan can result in insufficient security assurance, delayed vulnerability detection, and a degradation of the product's security over time.
5.2.9	Failure to establish secure distribution mechanisms for updates and related information

Section of this document	Description of the risk mitigated
	can result in delayed remediation, inconsistent deployment of updates, and continued exposure to vulnerabilities.
5.3.2	Failure to provide capability to receive report can result in missed or delayed vulnerability handling, reduced trust from external stakeholders, and increased cybersecurity risk.
5.3.3	Failure to perform effective vulnerability monitoring can result in unrecognized exposure to known and unknown vulnerabilities and delayed mitigation.
5.3.4	Failure to identify potentially impacted software components from a vulnerability can result in exploitable vulnerabilities remaining undetected within the product.
5.3.5	Failure to identify potentially impacted hardware components from a vulnerability can result in exploitable vulnerabilities remaining undetected within the product.
5.3.6	Failure to perform regular testing can result in undetected vulnerabilities and degradation of the product's security over time.
5.3.7	Failure to perform regular reviews can result in outdated risk assessments, misaligned controls and related documentation, and insufficient protection against evolving threats.
5.4.2	Failure to perform the initial assessment can result in inefficient handling, misclassification of vulnerabilities, or overlooked risks.
5.4.3	Failure to perform a structured vulnerability risk assessment can result in inappropriate prioritization, inefficient allocation of resources, and increased exposure to high-risk vulnerabilities.
5.5.2	Failure to perform effective remediation decision making can result in inappropriate or ineffective treatment of vulnerabilities, prolonged exposure to security risks, and inconsistent handling across products and components.
5.5.3	Failure to perform effective remediation development activities can result in incomplete or ineffective mitigation of vulnerabilities, introduction of new defects or vulnerabilities, and continued exposure to cybersecurity risks.
5.5.4	Failure to perform effective testing and validation can result in incomplete remediation, continued exposure to exploitation, introduction of new risks, or degradation of product functionality and reliability.

Section of this document	Description of the risk mitigated
5.6.2	Failure to perform effective release activities of the security updates can result in delayed deployment of remediation, increased exposure to vulnerabilities, inconsistent application of updates, or reduced trust in the product.
5.6.3	Failure to perform effective publication and communication activities can result in insufficient awareness of vulnerabilities, incorrect or delayed application of remediation measures, inconsistent understanding of risks, or reduced trust in the product and its security posture.
5.7.2	Failure to perform appropriate post-release actions can result in ineffective or incomplete remediation, repeated occurrence of similar vulnerabilities, undetected adverse effects following remediation deployment, reduced confidence in remediation measures, and missed opportunities for improving product security and development practices.

Annex B (informative)

Relationships of this document with other international standards

- 1694 This document builds upon the following international standards and technical report, adapting
1695 their terminology and process context, where appropriate, to align with Regulation (EU)
1696 2024/2847 (CRA) ^[1].
- 1697 — [EN ISO/IEC 29147:2020](#) - guidelines on receiving, processing and disclosing vulnerability
1698 reports, and on distributing remediation information to affected users;
 - 1699 — [EN ISO/IEC 30111:2020](#) - guidelines on how to investigate, process and resolve potential
1700 vulnerabilities; the process baseline in this document refines and partly elevates to “shall”
1701 requirements;
 - 1702 — [ISO/IEC TR 5895:2022](#) - extends [EN ISO/IEC 29147:2020](#) and [EN ISO/IEC 30111:2020](#) and
1703 clarifies and increases the application and implementation of and in MPCVD settings.
 - 1704 [EN ISO/IEC 30111:2020](#) and [EN ISO/IEC 29147:2020](#) use the term “vendor” where CRA uses
1705 “manufacturer”.
- 1706 In addition, this document adds several elements that do not exist in the aforementioned
1707 standards at all:
- 1708 — a mandatory software bill of materials (SBOM) and hardware component identification (5.2.6
1709 [PRE-5], 5.2.7 [PRE-6]);
 - 1710 — an explicit regular testing and review regime with its own planning and execution clauses
1711 (5.2.8 [PRE-7], 5.3.6 [RCP-5], 5.3.7 [RCP-6]);
 - 1712 — a dedicated secure distribution mechanism requirement (5.2.9 [PRE-8]).
- 1713 The relationships between the vulnerability disclosure and handling activities described in the
1714 referenced standards above and in this document are shown in Figure B.1.

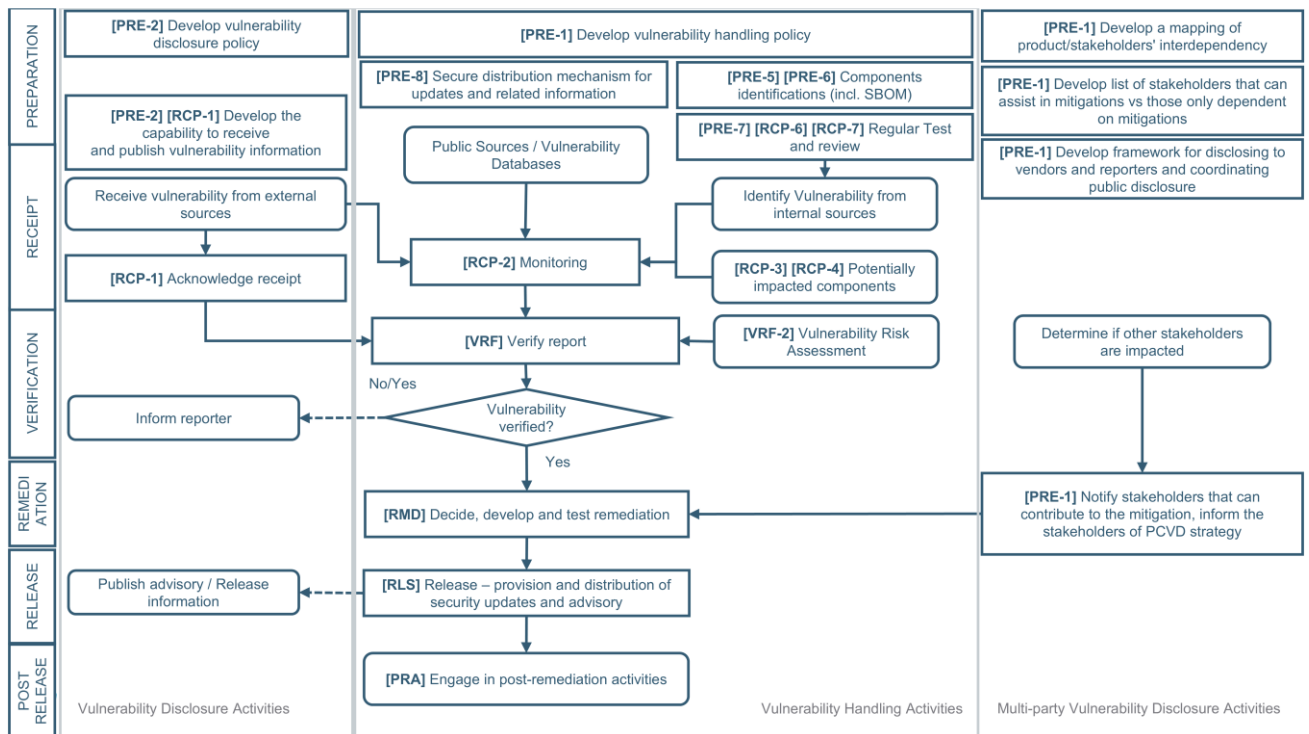


Figure B.1 — Relationships between referred standards and technical report and this document

Annex C (informative)

Additional guidance on vulnerability handling

C.1 General

This annex provides additional guidance for vulnerability handling processes across 5.2 to 5.7, covering preparation, receipt, verification, remediation, release, and post-release activities. This guidance supports the implementation of the vulnerability handling requirements specified in this document by providing practical considerations and implementation-oriented explanations for the corresponding activities.

National Cybersecurity organizations typically provide guidance on how to implement CVD.

C.2 [PRE-1] Vulnerability handling policy

[PRE-1-RQ-01] (see 5.2.2.3.1)

NOTE 1 For additional guidance on the vulnerability handling policy, refer to [EN ISO/IEC 30111:2020](#), 6.3.

NOTE 2 For implementation purposes the vulnerability handling policy can be supported by the relevant organizational processes of the manufacturers. For additional guidance on organizational framework, refer to [EN ISO/IEC 30111:2020](#), 6.4.

[PRE-1-RQ-02] (see 5.2.2.3.2)

NOTE 3 For additional guidance on responsibilities including the definition of usual activities, refer to [EN ISO/IEC 30111:2020](#):

- 6.5, Vendor CSIRT or PSIRT;
- 6.6, Responsibilities of the product business division;
- 6.7, Responsibilities of customer support and public relations;
- 6.8, Legal consultation.

NOTE 4 Expedited handling refers to the execution of vulnerability handling activities outside normal timelines or release cycles as defined in the vulnerability handling policy, based on the assessed risk and related prioritization.

NOTE 5 When an expedited remediation is not immediately achievable due to technical or external constraints, temporary mitigation measures can be implemented or prioritized to reduce the associated risk until a permanent solution is available.

NOTE 6 A target schedule serves as a guide for completing the activities of remediation development, as described in 5.5.

The target schedule for remediation development is intended to support a risk-based approach and does not imply fixed or predefined timelines. The target schedule can differ across products, product types, or categories of vulnerabilities and can be adapted to the specific circumstances of each case. Complex supply chains can have an impact on the target schedule.

1755 In defining an appropriate target schedule, the manufacturer can take into account relevant factors, such
1756 as:

1757 — product life cycle constraints;

1758 — the complexity of interactions with the supply chain and other entities involved in the remediation
1759 activities; and

1760 — characteristics of downstream stakeholders, considered at least at category level where relevant and
1761 appropriate.

1762 The target schedule can be defined per vulnerability or per category of vulnerabilities and can distinguish
1763 between expedited (prioritized) and non-expedited (non-prioritized) cases, where applicable. The target
1764 schedule serves as a planning guide for remediation development activities and remain proportionate to
1765 the identified risk.

1766 NOTE 7 For additional elements in the policy to further support the MPVD, refer to [ISO/IEC TR](#)
1767 [5895:2022](#), 7.2.2.

1768 **[PRE-1-RQ-03]** (see 5.2.2.3.3)

1769 NOTE 8 Some of the ways to monitor the effectiveness of the vulnerability handling process include but
1770 are not limited to, the following measurements:

1771 — Speed: monitor the time it takes to address a vulnerability to improve remediation speed;

1772 — Completeness: evaluate how many times the root cause analysis is performed in the verification phase
1773 and whether it was completely addressed in the remediation phase;

1774 — Effectiveness: monitoring of the effectiveness of the remediation after it is released, also considering
1775 the adoption rate.

1776 NOTE 9 For additional guidance on ways to monitor the effectiveness of the vulnerability handling
1777 process, refer to [EN ISO/IEC 30111:2020](#), 7.2.

1778 **[PRE-1-RQ-04]** (see 5.2.2.3.4)

1779 NOTE 10 Stakeholders can be identified at the level of stakeholder categories (e.g. dependent vendors,
1780 integrators, service providers, open-source projects), rather than individual organizations or persons.

1781 NOTE 11 For completeness, the MPCVD life cycle for each product can be further described by [ISO/IEC](#)
1782 [TR 5895:2022](#), 8.

1783 NOTE 12 This requirement reflects preparedness for multi-party coordinated vulnerability handling as
1784 described in [ISO/IEC TR 5895:2022](#), 7.2.2, including the establishment and maintenance of relationships
1785 with anticipated dependent vendors (downstream stakeholders) in the supply chain.

1786 **[PRE-1-RC-01]** (see 5.2.2.4.1)

1787 NOTE 13 For additional guidance on the embargo period, refer to [EN ISO/IEC 29147:2020](#), 5.6.8.

1788 NOTE 14 For additional guidance on the disclosure strategy, refer to [ISO/IEC TR 5895:2022](#), 7.3.1 and
1789 7.3.2.

1790 **C.3 [PRE-2] Coordinated vulnerability disclosure policy**

1791 **[PRE-2-RQ-01]** (see 5.2.3.3.1)

1792 NOTE 1 For additional guidance on the CVD policy, refer to [EN ISO/IEC 29147:2020](#), 9.

1793 **[PRE-2-RQ-03]** (see 5.2.3.3.3)

1794 NOTE 2 For additional guidance on policy elements, refer to [EN ISO/IEC 29147:2020](#), 9.2.2 and 6.2.2

1795 **[PRE-2-RQ-05]** (see 5.2.3.3.5)

1796 NOTE 3 For additional guidance on recommended policy elements, refer to [EN ISO/IEC 29147:2020](#), 9.3.

1797 **[PRE-2-RC-01]** (see 5.2.3.4.1)

1798 NOTE 4 For additional guidance on third-party rights, refer to [EN ISO/IEC 29147:2020](#), 9.4.2.

1799 **[PRE-2-RC-02]** (see 5.2.3.4.2)

1800 NOTE 5 For additional guidance on accessibility requirements, refer to [EN 301 549 v3.2.1](#).

1801 **C.4 [PRE-3] Confidentiality of vulnerability information**

1802 **[PRE-3-RQ-01]** (see 5.2.4.3.1)

1803 NOTE 1 For additional guidance related to this requirement, refer to [EN ISO/IEC 29147:2020](#), 6.7.

1804 NOTE 2 Operational security can be provided throughout all phases of the vulnerability handling
1805 activities for example internal GitHub or tracking systems.

1806 **[PRE-3-RQ-02]** (see 5.2.4.3.2)

1807 NOTE 3 For additional guidance related to this requirement, refer to [EN ISO/IEC 30111:2020](#), 7.3.

1808 **[PRE-3-RC-01]** (see 5.2.4.4.1)

1809 NOTE 4 The secure communication mechanisms are appropriate to the sensitivity of the information
1810 being exchanged and :

1811 — support the confidential transmission of sensitive information;

1812 — protect the integrity of exchanged information.

1813 NOTE 5 For additional guidance on secure communication, refer to [EN ISO/IEC 29147:2020](#), 5.8.

1814 **C.5 [PRE-4] On-going communication**

1815 **[PRE-4-RQ-01]** (see 5.2.5.3.1)

1816 NOTE 1 Records can include:

1817 — Date/time;

1818 — Stakeholder type;

1819 — Communication channel;

1820 — Summary of content;

1821 — Link to vulnerability record (if applicable).

- 1822 NOTE 2 The phases in which is important that the communication is happening are:
- 1823 — Acknowledgement that the vulnerability report has been received - in receipt
 - 1824 — Status updates in the verification phase, and cases in which is terminated;
 - 1825 — Status about the resolutions and disclosure timeline.
- 1826 During these phases it is important to communicate status updates, significant new information, changes
1827 to existing plans or disclosure timings.
- 1828 For additional guidance on communication with reporters and other stakeholder, refer to [EN ISO/IEC](#)
1829 [29147:2020](#), 6.5.
- 1830 EXAMPLE Example of communication that can occur at different stages for the vulnerability handling
1831 and disclosure process can be as follows:
- 1832 EXAMPLE Communication between the manufacturer, reporters, and other stakeholders can occur at
1833 different stages of the vulnerability handling life cycle. Depending on the vulnerability and the CVD process,
1834 communications can include:
- 1835 EXAMPLE During receipt
- 1836 — acknowledgment of receipt of the vulnerability report;
 - 1837 — status updates regarding the report handling process.
- 1838 EXAMPLE During verification
- 1839 — requests for additional information where necessary to assess or reproduce the vulnerability;
 - 1840 — communication of the outcome of the verification and investigation activities;
 - 1841 — where applicable, communication of the justification for terminating the handling process;
 - 1842 — agreement on disclosure conditions and embargo periods.
- 1843 EXAMPLE During remediation
- 1844 — communication regarding the planned remediation and release timelines;
 - 1845 — communication of changes to anticipated timelines;
 - 1846 — communication of modifications to agreed embargo periods, particularly in multi-party CVD scenarios
1847 where dependencies on multiple stakeholders can affect remediation activities.
- 1848 EXAMPLE During release
- 1849 — confirmation of the planned release date;
 - 1850 — notification that remediation measures and associated public disclosures have been released;
 - 1851 — confirmation that the vulnerability handling case has been closed.
- 1852 EXAMPLE During post-release
- 1853 — communication of updates or corrections to previously released remediation measures;

- communication of revised vulnerability information;
- continued engagement with relevant stakeholders where additional actions are required.

EXAMPLE The timing, content, and frequency of communications can vary depending on the severity of the vulnerability, CVD arrangements, stakeholder involvement, and the status of remediation activities.

[PRE-4-RQ-02] (see 5.2.5.3.2)

NOTE 3 For additional guidance on general accessible modes, refer to [EN 301 549 v3.2.1](#).

C.6 [PRE-5] Identification of software components

[PRE-5-RQ-01] (see 5.2.6.3.1)

EXAMPLE 1 The Figure C.1 illustrates example of components to be identified and documented at minimum as per [PRE-5-RQ-01] (see 5.2.6.3.1) and [PRE-5-RQ-02] (see 5.2.6.3.2). If the SBOM does not include all dependencies, SBOM author can include information on SBOM completeness (“known-unknowns”) as per [PRE-5-RC-02] (see 5.2.6.4.2)

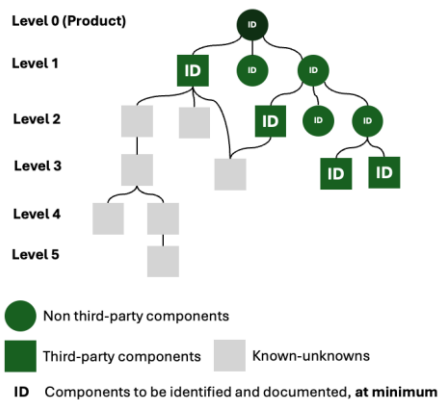


Figure C.1 — Example of a component structure

[PRE-5-RQ-05] (see 5.2.6.3.5)

NOTE 1 Some examples of the machine-readable formats widely used by software ecosystem stakeholders to generate and consume SBOMs are:

- Software Package Data eXchange (SPDX), [ISO/IEC 5962:2021](#);
- CycloneDX, [ECMA-424:2025](#).

[PRE-5-RQ-08] (see 5.2.6.3.8)

NOTE 2 For additional guidance on the timestamp format, refer to [ISO 8601-1:2019](#) (e.g. 2024-05-23T13:51:37Z).

[PRE-5-RQ-09] (see 5.2.6.3.9)

NOTE 3 Identifier(s) can be used to identify a component or serve as a look-up key for relevant databases.

EXAMPLE 2 The component identifier can be:

- 1880 — Common Platform Enumeration (CPE as defined in NIST CPE2.3 [\[13\]](#));
- 1881 — Package URL (PURL as defined in [ECMA-427:2025](#));
- 1882 — SoftWare Hash IDentifier (SWHID as defined in [ISO/IEC 18670:2025](#)); or
- 1883 — OmniBOR Artifact Identifier.

1884 EXAMPLE If more than one component identifier is available, all of them can be stated.

1885 **[PRE-5-RC-01]** (see 5.2.6.4.1)

1886 NOTE 4 Source code hashes identify the upstream components from which the product is built, so that
 1887 vulnerabilities that could be inherited can be identified. The software component can also have its own
 1888 hash.

1889 NOTE 5 In certain development models, such as those involving the integration of individual code
 1890 snippets from open-source projects, it could not be possible to include the hash and the corresponding
 1891 algorithm in the SBOM, as no complete artefact from the original component exists.

1892 **C.7 [PRE-6] Identification of hardware components**

1893 **[PRE-6-RQ-02]** (see 5.2.7.3.2)

1894 NOTE 1 A taxonomy of methods for identifying the product is documented in [prEN IEC 61360-7:2025](#).
 1895 The document referenced can be found online with reference id 0112/2///61360_7#AAS005#001 at the
 1896 following web address https://cdd.iec.ch/cdd/iec61360-7/iec61360-7.nsf/classes/0112-2---61360_7%23AAS005
 1897

1898 NOTE 2 Further available information can be recorded, such as:

- 1899 — part number;
- 1900 — serial number;
- 1901 — batch number;
- 1902 — production date.

1903 **C.8 [PRE-8] Secure distribution mechanism for updates and related** 1904 **information**

1905 **[PRE-8-RQ-02]** (see 5.2.9.3.2)

1906 NOTE This includes mechanisms for providing advisories, release notes, installation information, and
 1907 notifications. Way of publishing the information can include an implementation such as a dedicated portal.

1908 There are different ways that can be considered:

- 1909 — where applicable, establishing channels (e.g. e-mail alerts, in-app notifications, automated
 1910 RSS/security feeds, or user interface to alert relevant stakeholders to the availability of critical security
 1911 updates without delay;
- 1912 — Ensuring that the relevant advisory information is accessible to the reader and is directly available or
 1913 linked at the point of update distribution to prevent information gaps during the patching process.

1914 **C.9 [RCP-1] Capability to receive reports**

1915 **[RCP-1-RQ-01]** (see 5.3.2.3.1)

1916 NOTE 1 For additional guidance on mechanisms to receive reports, refer to [EN ISO/IEC 29147:2020](#),
1917 6.2.2. and, for example, of information to request in a report, see [EN ISO/IEC 29147:2020](#), Annex B.

1918 **[RCP-1-RQ-02]** (see 5.3.2.3.2)

1919 NOTE 2 For additional guidance on mechanisms for tracking vulnerability information or reports, refer
1920 to [EN ISO/IEC 29147:2020](#), 6.2.4.

1921 **[RCP-1-RQ-04]** (see 5.3.2.3.4)

1922 NOTE 3 For additional guidance on mechanisms for acknowledgement of received vulnerability
1923 information or reports, refer to [EN ISO/IEC 29147:2020](#), 6.2.5.

1924 **[RCP-1-RC-02]** (see 5.3.2.4.2)

1925 NOTE 4 The preliminary status information, can indicate whether the report is under active
1926 investigation, requires further information from the reporter, or has been initially flagged as incomplete,
1927 duplicate, or otherwise out of scope.

1928 **[RCP-1-RC-03]** (see 5.3.2.4.3)

1929 NOTE 5 For additional guidance on coordinator involvement, refer to [EN ISO/IEC 29147:2020](#), 5.5.5 and
1930 6.6, and for the coordinator role definition refer to [EN ISO/IEC 29147:2020](#), 8.

1931 **C.10 [VRF-1] Initial assessment**

1932 **[VRF-1-RC-01]** (see 5.4.2.4.1)

1933 NOTE 1 Where the root cause of the issue highlights that the vulnerability is related to components
1934 outside the scope of responsibility, the relevant information can be communicated to the appropriate
1935 external stakeholder, in accordance with the CVD policy.

1936 NOTE 2 For root cause analysis, a methodical approach such as that described in [EN 62740:2015](#) can be
1937 used.

1938 **C.11 [VRF-2] Vulnerability risk assessment**

1939 **[VRF-2-RQ-01]** (see 5.4.3.3.1)

1940 NOTE 1 The assessment can consider:

- 1941 — the likelihood of exploitation;
- 1942 — the potential impact on the product's cybersecurity objectives, including:
- 1943 — confidentiality;
- 1944 — integrity;
- 1945 — availability.
- 1946 — relevant contextual factors, such as:

1947 — product context and deployment environment;

1948 — exposure of the affected components;

1949 — presence of mitigation measures or controls;

1950 — affected users.

1951 NOTE 2 The severity of a vulnerability can be determined using the most commonly deployed
1952 conditions of affected products when possible to assist the prioritization.

1953 **C.12 [RMD-3] Remediation test**

1954 **[RMD-3-RQ-02]** (see 5.5.4.3.2)

1955 NOTE Testing and validation activities can be conducted in coordination with relevant upstream and
1956 downstream stakeholders, particularly in MPCVD scenarios.

1957 **C.13 [RLS-1] Security update release**

1958 **[RLS-1-RQ-02]** (see 5.6.2.3.2)

1959 NOTE There are several possible distribution mechanisms, including automatic and manual. The
1960 product and infrastructure design need to provide an adequate distribution mechanism, taking into
1961 account the product's intended purpose and its reasonably foreseeable use.

1962 **C.14 [RLS-2] Release information**

1963 **[RLS-2-RQ-01]** (see 5.6.3.3.1)

1964 NOTE For additional guidance on publishing advisories, refer to [EN ISO/IEC 29147:2020](#), 7.

Annex ZA (informative)

Relationship between this European Standard and the essential cybersecurity requirements of Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act) aimed to be covered

This European Standard has been prepared under a Commission's standardization request C(2025)618 ('M/606')¹⁾ to provide one voluntary means of conforming to the essential cybersecurity requirements of Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act).

Once this standard is cited in the Official Journal of the European Union under that Regulation, compliance with the normative clauses of this standard given in Table ZA.1 confers, within the limits of the scope of this standard, a presumption of conformity with the corresponding essential cybersecurity requirements of that Regulation, and associated EFTA regulations.

Where a definition in this standard differs from a definition of the same term set out in Regulation (EU) 2024/2847, the differences shall be indicated in this Annex Z. Where a reference from a clause of this standard to risk assessment is made, the risk assessment process needs to be in compliance with Regulation (EU) 2024/2847. For the purpose of using this standard in support of the requirements set out in Regulation (EU) 2024/2847, the definitions set out in the Regulation prevail.

Table ZA.1 — Correspondence between this European Standard and Annex I of the Cyber Resilience Act

Essential cybersecurity requirements of Regulation (EU) 2024/2847	Clause(s)/sub-clause(s) of this EN	Remarks/Notes
Annex I, Part 2, (1)	5.2.6 [PRE-5], 5.2.7 [PRE-6], 5.3.3 [RCP-2], 5.3.4 [RCP-3], 5.3.5 [RCP-4]	
Annex I, Part 2, (2)	5.2.2 [PRE-1], 5.2.4 [PRE-3], 5.2.5 [PRE-4], 5.4.2 [VRF-1],	

¹⁾ COMMISSION IMPLEMENTING DECISION of 3.2.2025 on a standardisation request to the European Committee for Standardisation (CEN), the European Committee for Electrotechnical Standardisation (Cenelec) and the European Telecommunications Standards Institute (ETSI) as regards products with digital elements in support of Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act).

Essential cybersecurity requirements of Regulation (EU) 2024/2847	Clause(s)/sub-clause(s) of this EN	Remarks/Notes
	5.4.3 [VRF-2], 5.5.2 [RMD-1], 5.5.3 [RMD-2], 5.5.4 [RMD-3], 5.6.2 [RLS-1], 5.7.2 [PRA-1]	
Annex I, Part 2, (3)	5.2.8 [PRE-7], 5.3.6 [RCP-5], 5.3.7 [RCP-6], 5.7.2 [PRA-1]	
Annex I, Part 2, (4)	5.2.9 [PRE-8], 5.2.5 [PRE-4], 5.6.3 [RLS-2]	
Annex I, Part 2, (5)	5.2.3 [PRE-2]	
Annex I, Part 2, (6)	5.2.3 [PRE-2], 5.2.4 [PRE-3], 5.3.2 [RCP-1]	
Annex I, Part 2, (7)	5.2.9 [PRE-8], 5.6.2 [RLS-1], 5.7.2 [PRA-1]	
Annex I, Part 2, (8)	5.2.4 [PRE-3], 5.2.9 [PRE-8], 5.6.2 [RLS-1], 5.6.3 [RLS-2]	

1992 **WARNING — Presumption of conformity stays valid only as long as a reference to this**
1993 **European Standard is maintained in the list published in the Official Journal of the**
1994 **European Union. Users of this standard should consult frequently the latest list published**
1995 **in the Official Journal of the European Union.**

1996 **WARNING — Other Union legislation may be applicable to the products falling within the**
1997 **scope of this standard**

Bibliography

1998

- 1999 [1] REGULATION (EU) 2024/2847 OF THE EUROPEAN PARLIAMENT AND OF THE COUNCIL
2000 of 23 October 2024 on horizontal cybersecurity requirements for products with digital
2001 elements and amending Regulations (EU) No 168/2013 and (EU) No 2019/1020 and
2002 Directive (EU) 2020/1828 (Cyber Resilience Act)
- 2003 [2] C(2025)618 – Standardisation request M/606
- 2004 [3] EN 301 549 v3.2.1, *Accessibility requirements for ICT products and services*
- 2005 [4] prEN 40000-1-2:2025, *Cybersecurity requirements for products with digital elements -*
2006 *Part 1-2: Principles for cyber resilience*
- 2007 [5] RFC 9116:2022, A File Format to Aid in Security Vulnerability Disclosure
- 2008 [6] ISO/IEC TR 5895:2022, *Cybersecurity — Multi-party coordinated vulnerability disclosure*
2009 *and handling*
- 2010 [7] ISO/IEC 20153:2025, *Information technology — OASIS Common Security Advisory*
2011 *Framework (CSAF) v2.0 Specification*
- 2012 [8] EN ISO/IEC 29147:2020, *Information technology - Security techniques - Vulnerability*
2013 *disclosure (ISO/IEC 29147:2018)*
- 2014 [9] EN ISO/IEC 30111:2020, *Information technology - Security techniques - Vulnerability*
2015 *handling processes (ISO/IEC 30111:2019)*
- 2016 [10] ISO/IEC 5962:2021, *Information technology — SPDX® Specification V2.2.1*
- 2017 [11] ECMA-424:2025, *CycloneDX Bill of Materials Specification (ECMA-424)*
- 2018 [12] ISO 8601-1:2019, *Date and time — Representations for information interchange — Part 1:*
2019 *Basic rules*
- 2020 [13] Common Platform Enumeration 2.3
- 2021 [14] ECMA-427:2025, *Package-URL (PURL) specification*
- 2022 [15] ISO/IEC 18670:2025, *Information technology — SoftWare Hash IDentifier (SWHID)*
2023 *Specification V1.2*
- 2024 [16] prEN IEC 61360-7:2025, *Standard data element types with associated classification*
2025 *scheme - Part 7: Data dictionary of cross-domain concepts*
- 2026 [17] EN 62740:2015, *Root cause analysis (RCA)*